T

TPOS

THE OPERATING SYSTEM FOR TRAILER DEALERS

Product Specification

A business-level, implementation-agnostic specification — sufficient for an independent team to rebuild the system from scratch in the stack and architecture of their choosing.

Document v1.2 · Functional & non-functional requirements · B&W wireframes · Appendices A–N · Bid package · Confidential draft

Executive Overview

TPOS is a multi-tenant vertical SaaS that runs an independent trailer dealership's entire operation — its **public storefront** and its whole **back office** — on one shared record of truth, where a single trailer is seen through **12 role lenses** (inventory → deal → work order → invoice → title → delivery → listing). Sold **hosted** (monthly), **licensed** (annual), or **self-hosted** (one-time). The Phase-1 MVP is ≈ **6–12 months** across **5 delivery stages** (demo → GA).

The product

- **Who:** small-to-mid used/refurbished commercial-trailer dealers, replacing a website builder + CRM + spreadsheets + QuickBooks + listing sites with one role-aware platform.
- **Core loop:** acquire → recondition → price → list → lead → quote → finance → title → deliver → book — each stage hands the *same* record to the next role.
- **Pricing:** Hosted $199–$1,290/mo · annual license · one-time self-host.

Delivery stages (Appendix N)

- **A · Internal demo** — prototype, mock data *(already built)*.
- **B · Sales demo** — polished facade to win design partners (~1–3 pw).
- **C · Alpha** — real architecture, core sell-loop, 1–2 partner dealers.
- **D · Beta** — real PII + money; pen-test + GLBA Safeguards baseline.
- **E · Release 1.0** — self-serve signup, live billing, 99.9% SLA.

The bid envelope (Appendices J–M)

- **Scope priced:** Phase-1 MVP cutline — core sell-loop, hosted-only.
- **Effort:** ≈ **95–175 person-weeks** (~3–4 FTE + designer + PM) — a planning range, not a quote.
- **Tightens once 4 levers fixed:** scope · delivery model · design ownership · jurisdiction.

Tech stack at a glance (Appendix D)

Database	**PostgreSQL** + Row-Level Security (SQLite per self-host tenant)
Isolation	Shared schema · `tenant_id` everywhere · `FORCE RLS` + `SET LOCAL`
App	**Modular monolith** — Django/DRF *or* NestJS + Next.js
Data path	PgBouncer txn-pooling · thin typed SQL on hot paths
Reads	Materialized read models (CQRS-lite) + replicas + cache
Storefront	SSR + edge/CDN cache · S3 object storage (MinIO self-host)
Integrations	Stripe Connect · Twilio · Postmark · e-sign · QuickBooks (file→API)
Security	Argon2id · MFA · audit log · KMS · TLS + at-rest encryption
Scaling	Single primary + replicas · HASH(`tenant_id`) partitions · defer Citus

Reading guide

Product & requirements	§1–14
Data & API	App. A–B · `schema.sql` · `openapi.yaml`
Architecture	App. C (scaling) · D (decisions)
Build-critical	App. E security · F onboarding · G formulas · H notifications · I accounting
Bid & delivery	App. J scope · K integrations · L RACI · M estimate · N stages

Implementation-agnostic: stack choices are load-bearing recommendations *with rationale* (Appendix D), not mandates — the build team owns the final call. Effort/cost figures are order-of-magnitude planning guidance.

Contents

Executive Overview

2. Product Vision & Business Model
3. Multi-Tenancy & Deployment Modes
4. Personas & Roles
5. Domain Model — One Record, Many Lenses
6. The Trailer Lifecycle
7. Functional Specification by Role
8. Public Storefront
9. Cross-Cutting Capabilities
10. Reporting & KPIs
11. Roles & Permissions Matrix
12. External Integrations
13. Non-Functional Requirements
14. Acceptance Criteria
15. Glossary
16. Appendix A — Data Dictionary & Relational Schema
17. Appendix B — API Reference
18. Appendix C — Performance & Scaling
19. Appendix D — Architecture Decisions & Roads Not Taken
20. Appendix E — Security, Privacy & Compliance
21. Appendix F — Onboarding & Data Import
22. Appendix G — Derived-Field Formulas
23. Appendix H — Notification & Document Catalog
24. Appendix I — Accounting Export (QuickBooks & Beyond)
25. Appendix J — MVP Scope Matrix & Release Roadmap
26. Appendix K — Integration & Third-Party Register
27. Appendix L — Assumptions, Delivery Model & RACI
28. Appendix M — Estimation Worksheet (WBS)
29. Appendix N — Delivery Stages (Internal Demo → GA)

1 · Product Vision & Business Model

TPOS is a vertical SaaS that gives an independent trailer dealership one system to run both its **public storefront** and its entire **back office** — acquisition, reconditioning, pricing, marketing, sales, financing, titling, delivery and bookkeeping — on a single shared record of truth.

The market is fragmented small-to-mid dealers (used & refurbished commercial trailers: dry vans, flatbeds, reefers, lowboys, dumps, tankers, chassis) who today stitch together a website builder, a generic CRM, spreadsheets, QuickBooks and listing sites (TruckPaper, Facebook). TPOS replaces that stack with a purpose-built, role-aware platform.

Revenue model

Offering	Pricing	For	Notes
Hosted — Starter	$199 / month	Single lot, ≤ ~25 units	Storefront + CRM + inventory; core roles
Hosted — Growth	$499 / month	Multi-lot dealers	All roles, financing, dispatch, reporting
Hosted — Enterprise	$1,290 / month	Large / multi-location	Unlimited units & seats, API, SSO, priority support
Annual License	$9,900 / year	Dealers wanting to self-host	Right to run the software on own infrastructure; updates included
One-Time Purchase	$24,000 + $3,000/yr support	Buy-to-own	Perpetual self-host license; optional support & updates

The platform operator (TPOS, Inc.) additionally runs a **super-admin control plane** to provision tenants, meter usage, bill subscriptions, and support dealers (see §6.12).

Product principles

- **One record, many lenses.** A trailer is simultaneously inventory, a deal, a work order, an invoice line, a title file, a delivery, and a public listing. Every role edits the *same* entity through a view shaped to its job — never a copy.
- **The storefront is generated, not separate.** Inventory marked *available* is automatically published to the dealer's branded public site and syndicated to listing channels.
- **Role-first, not module-first.** Each user lands on a workspace built around their daily goals and decisions, not a generic menu of tables.

- **Auditable by default.** Price changes, discounts, status transitions and money movement are logged with who/when/why.

2 · Multi-Tenancy & Deployment Modes

Each dealership is a **tenant** with isolated data, its own users, branding, lots, inventory and storefront domain. The system must support three deployment modes from one codebase:

Mode	Hosting	Tenancy	Billing
Hosted (SaaS)	Operator-run cloud	Many tenants per deployment (logical isolation, per-tenant scoping on every query)	Recurring subscription, usage-metered
Licensed self-host	Dealer infrastructure	Typically single tenant; multi-tenant allowed	Annual license key, update channel
One-time self-host	Dealer infrastructure	Single tenant	Perpetual key; optional support plan

Requirement. Tenant isolation must be enforced at the data layer (no cross-tenant read/write possible), branding/config is per-tenant, and a tenant's storefront resolves on a custom domain or subdomain. The control plane (§6.12) exists only in hosted mode.

3 · Personas & Roles

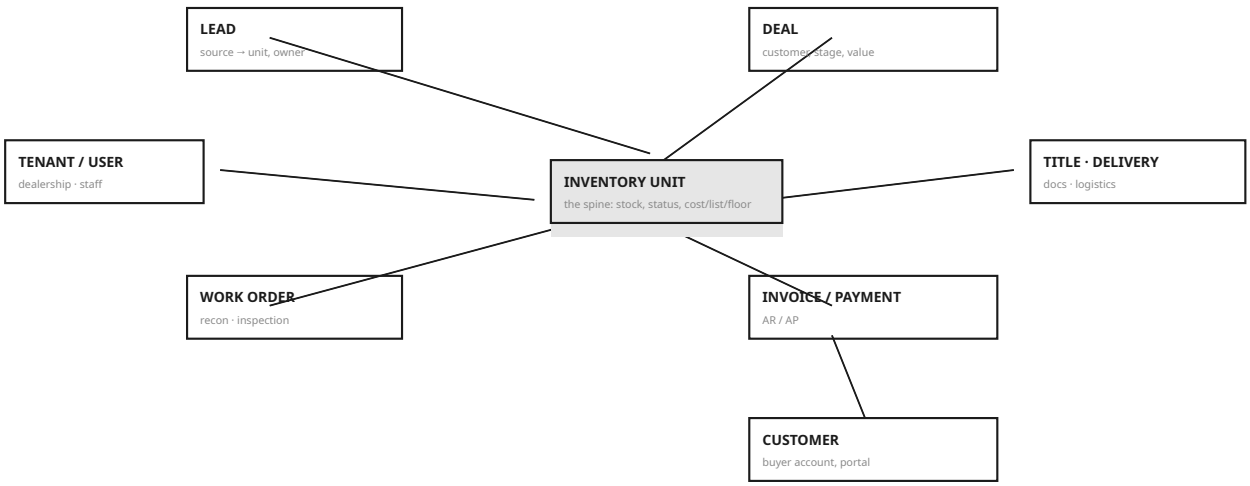
TPOS serves twelve roles across the dealership, plus the dealership's own customers and the platform operator. Each persona has a primary goal and a small set of "jobs to be done" that the system must make fast.

Role	Primary goal	Key jobs-to-be-done
Owner / Dealer Principal	Run a healthy, profitable business	See revenue, gross, turn & pipeline at a glance; spot aged inventory, overdue AR, stalled deals; manage the team
Lead Generation / BDC	Capture & route every inquiry fast	Triage the lead inbox, measure response time & sources, run campaigns, assign to sales
Salesperson	Work the pipeline & close	Advance deals through stages, build quotes, track follow-ups, manage customers
Sales Manager	Coach, forecast, approve	Compare rep performance, forecast the month, approve below-floor discounts
Pricing Analyst	Maximize margin & turn	Reprice against age & demand, monitor margin, compare market comps, approve changes

Inventory Manager	Source, recon, place & turn units	Track stock by status & location, manage intake & aging, push units into recon & to the lot
Service Technician	Recon & inspect units quickly	Work the work-order board, complete inspection checklists, log hours & parts
Office / Titles & Admin	Keep paperwork clean & legal	Track titles/DMV, collect deal documents, schedule signings & deliveries
Bookkeeper / Accounting	AR/AP, cash, month-end	Issue & collect invoices, record payments, pay bills, close the month, report P&L
Delivery Dispatch	Move units to buyers	Schedule deliveries, assign drivers/carriers, quote freight, track in-transit
Customer (buyer)	Buy with confidence, self-serve	View quotes, apply for financing, track delivery, sign & download documents
Platform Super-Admin	Operate the SaaS business	Provision & bill tenants, watch MRR/churn, monitor usage & system health, support dealers

4 · Domain Model — One Record, Many Lenses

The data model is small and tightly linked. The **Trailer (Inventory Unit)** is the spine; everything references it.



Entity-relationship overview. One trailer threads through inventory, deals, work orders, invoices, title and delivery; each role reads the same graph.

Core entities

Entity	Purpose	Key attributes
Tenant	A dealership	name, plan, branding, lots[], storefront domain, billing
User	A staff member	name, role(s), permissions, lot scope
Inventory Unit (Trailer)	The spine	stock #, type, year, make, length, axles, capacity, condition, photos, **cost**, **list**, **floor**, status, location, acquired/sold dates, views, lead-count
Lead	An inbound prospect	name, company, source, interest→Unit, status, owner→User, value, created
Customer	A buyer account	name, company, contacts, deals[], documents[]
Deal	A sales opportunity	customer, unit, stage, value, probability, salesperson, financing
Quote	A priced offer	unit, line items (price, prep, freight, tax), total, validity
Work Order	Recon / inspection / repair	unit, type, status, technician, tasks[], parts cost, hours est/actual

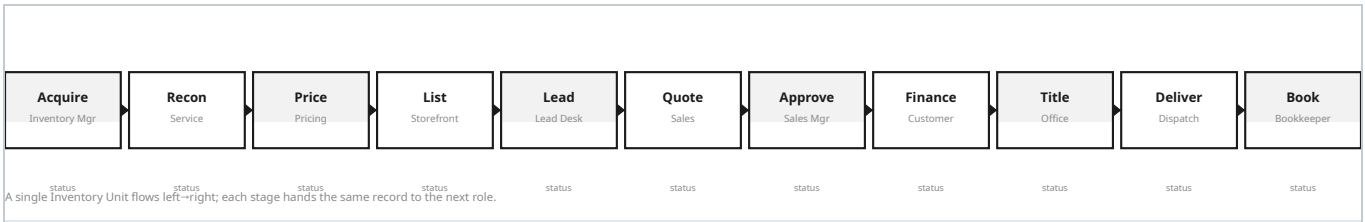
Invoice / Payment	Money in & out (AR/AP)	customer/vendor, unit, amount, status, dates, method
Title / Document	Legal & DMV paperwork	unit, title status, state, lien, document checklist & signatures
Delivery	Logistics of handoff	unit, deal, origin, destination, driver/carrier, status, ETA, freight cost

The status machine

An Inventory Unit moves through: `incoming → recon → available → pending → sold`. Status is the single field that re-shapes the unit across roles — e.g. *available* publishes it to the storefront; *pending* hides it from new leads; *sold* moves it to delivery & books revenue. The system must guard valid transitions and log each one.

5 · The Trailer Lifecycle

The end-to-end flow ties every role together. Each stage hands the same unit to the next role.



Trailer lifecycle — the same unit handed role to role from acquisition through booking the sale.

6 · Functional Specification by Role

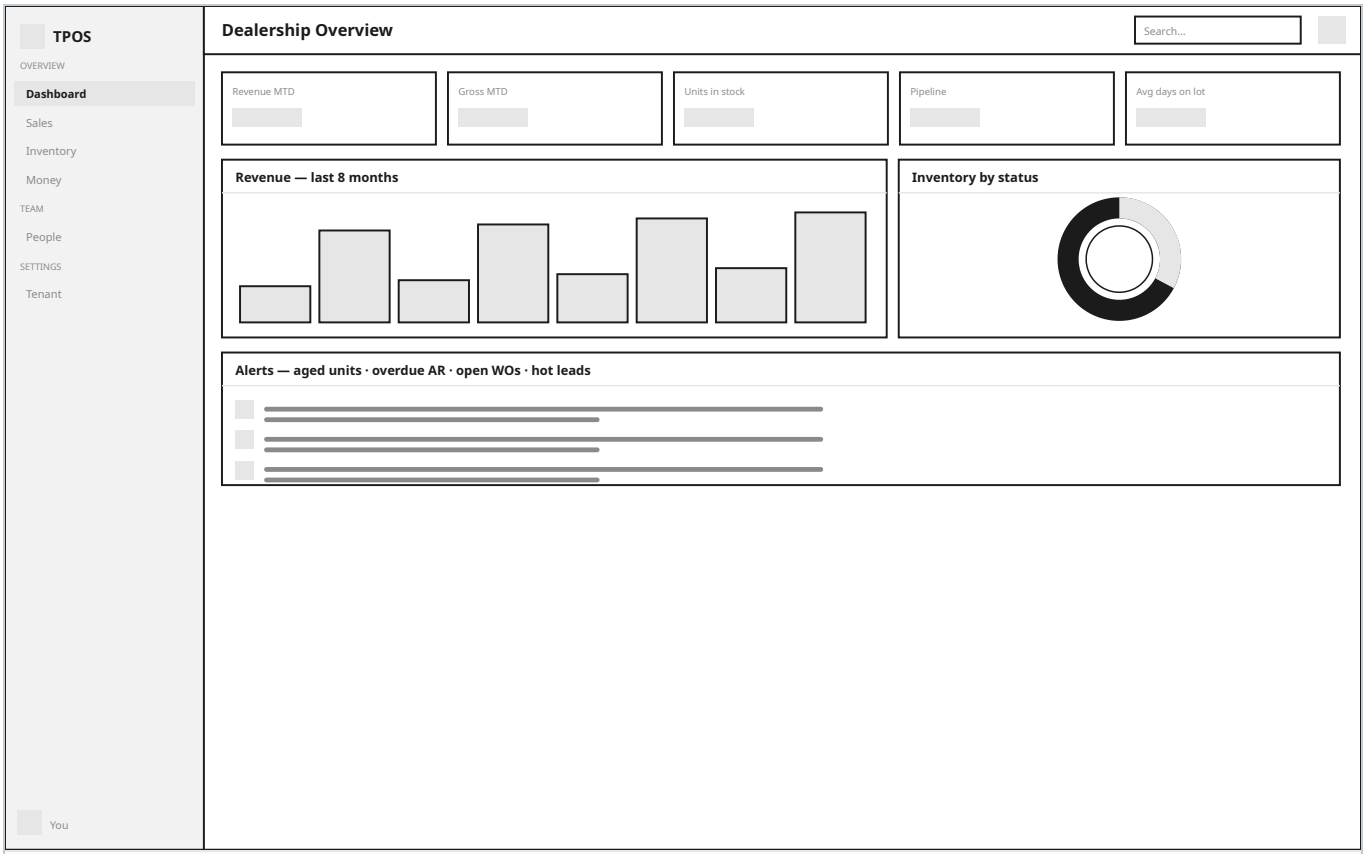
Each role below states its **goal**, the **screens** it owns, its **functional requirements** (what the system must let it do), and a **wireframe** of the primary workspace. Wireframes define information architecture and layout only — visual design, components and stack are the build team's choice.

6.1 Owner / Dealer Principal

Goal. Run a healthy, profitable business at a glance.

Functional requirements

- Executive dashboard: revenue, gross, units, pipeline, days-on-lot.
- Cross-role alert feed: aged inventory, overdue AR, open work orders, hot/new leads.
- Drill into Sales and Inventory; manage team & tenant settings & billing.



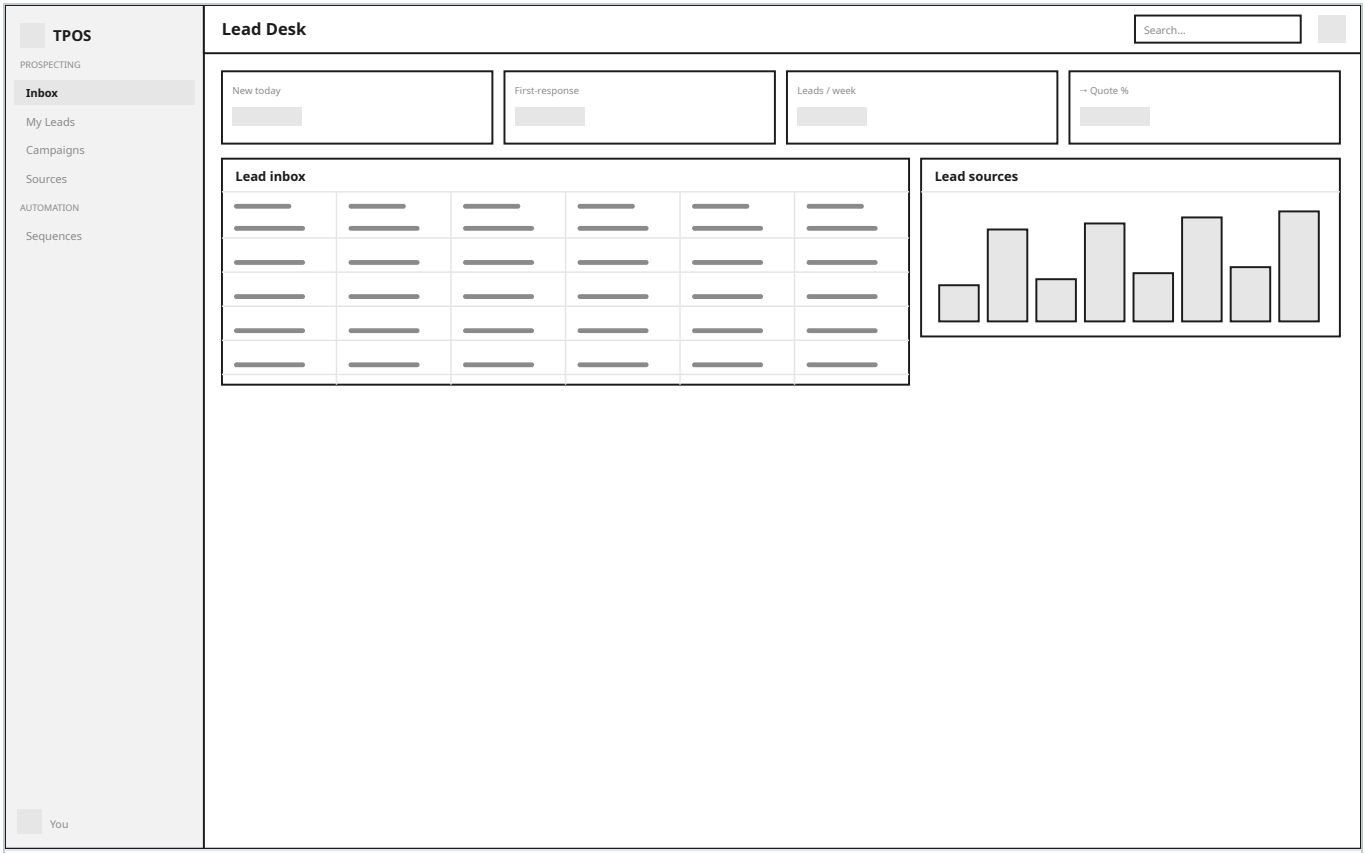
Wireframe — Owner / Dealer Principal primary workspace (layout & IA only).

6.2 Lead Generation / BDC

Goal. Capture every inquiry and route it fast.

Functional requirements

- Unified lead inbox (web, listing sites, phone, walk-in) with age & first-response timers.
- Assign/route leads to salespeople; one-click call/email.
- Source & campaign analytics: volume, cost-per-lead, conversion to quote.



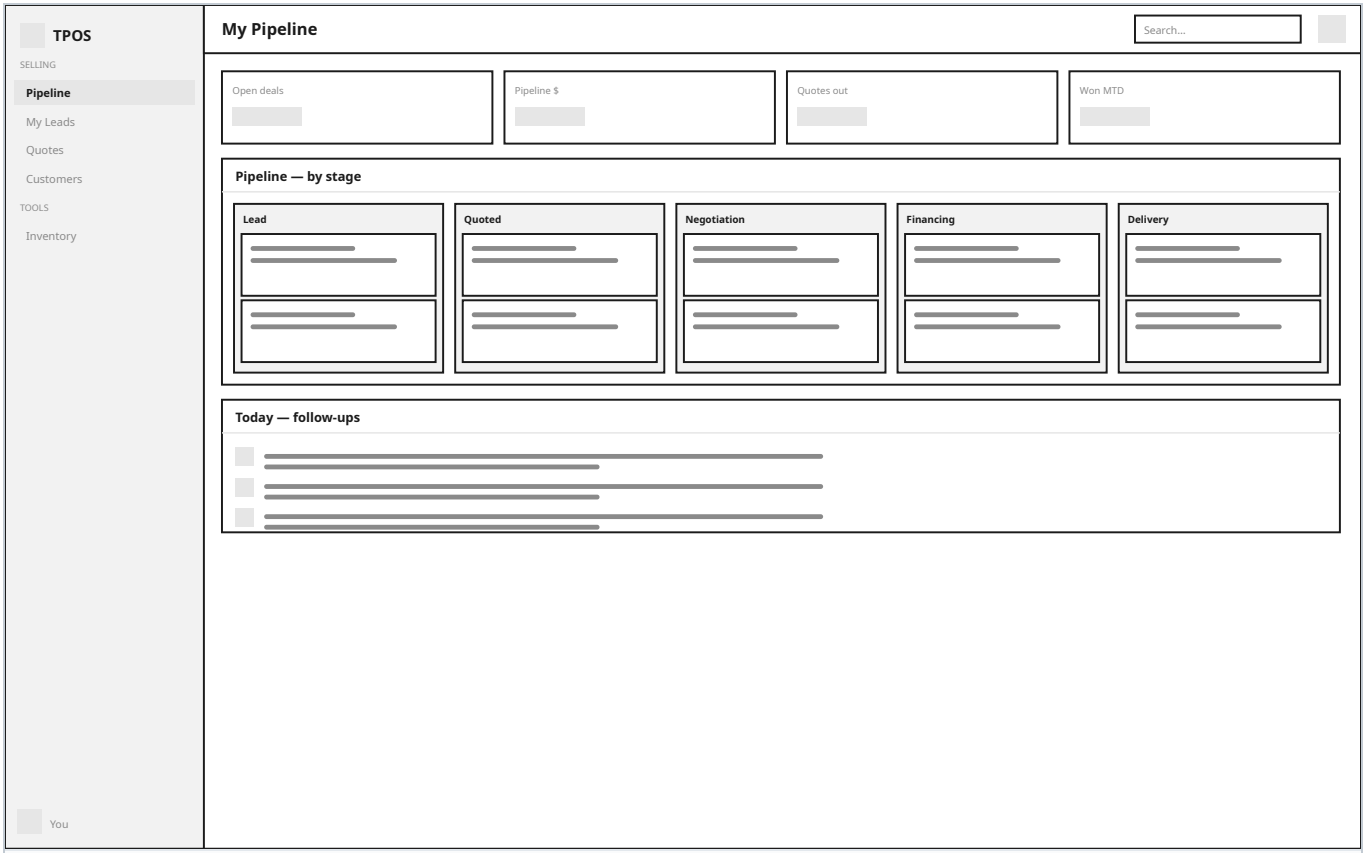
Wireframe — Lead Generation / BDC primary workspace (layout & IA only).

6.3 Salesperson

Goal. Work the pipeline and close deals.

Functional requirements

- Kanban pipeline of own deals across stages with probability & last-touch.
- Quote builder tied to a unit (price, prep, freight, tax → total).
- Daily follow-up tasks; customer accounts and history.



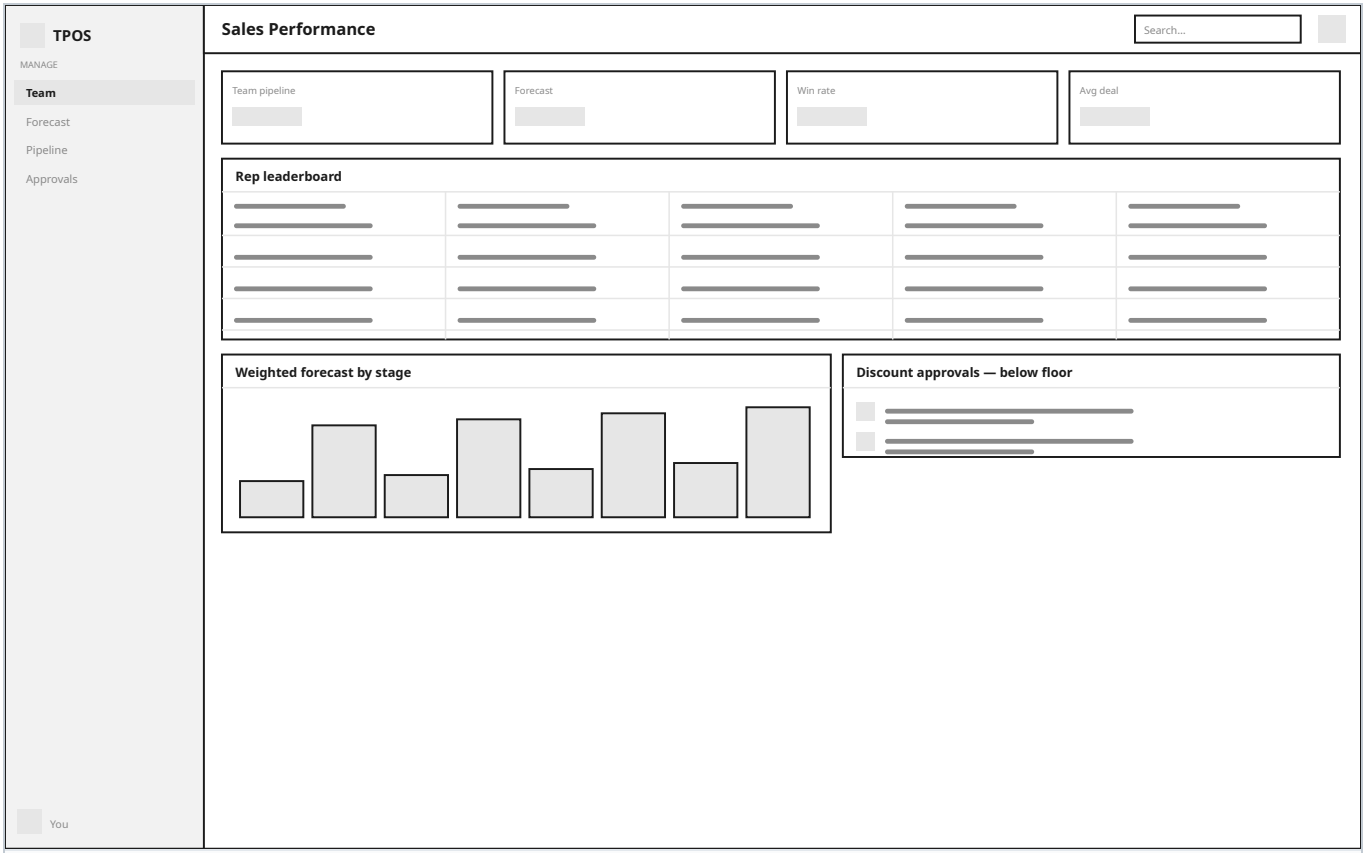
Wireframe — Salesperson primary workspace (layout & IA only).

6.4 Sales Manager

Goal. Coach the team, forecast, approve.

Functional requirements

- Rep leaderboard (deals, pipeline, won, win-rate) and conversion funnel.
- Weighted forecast by stage.
- Approve/deny/counter below-floor discounts — logged with reason.



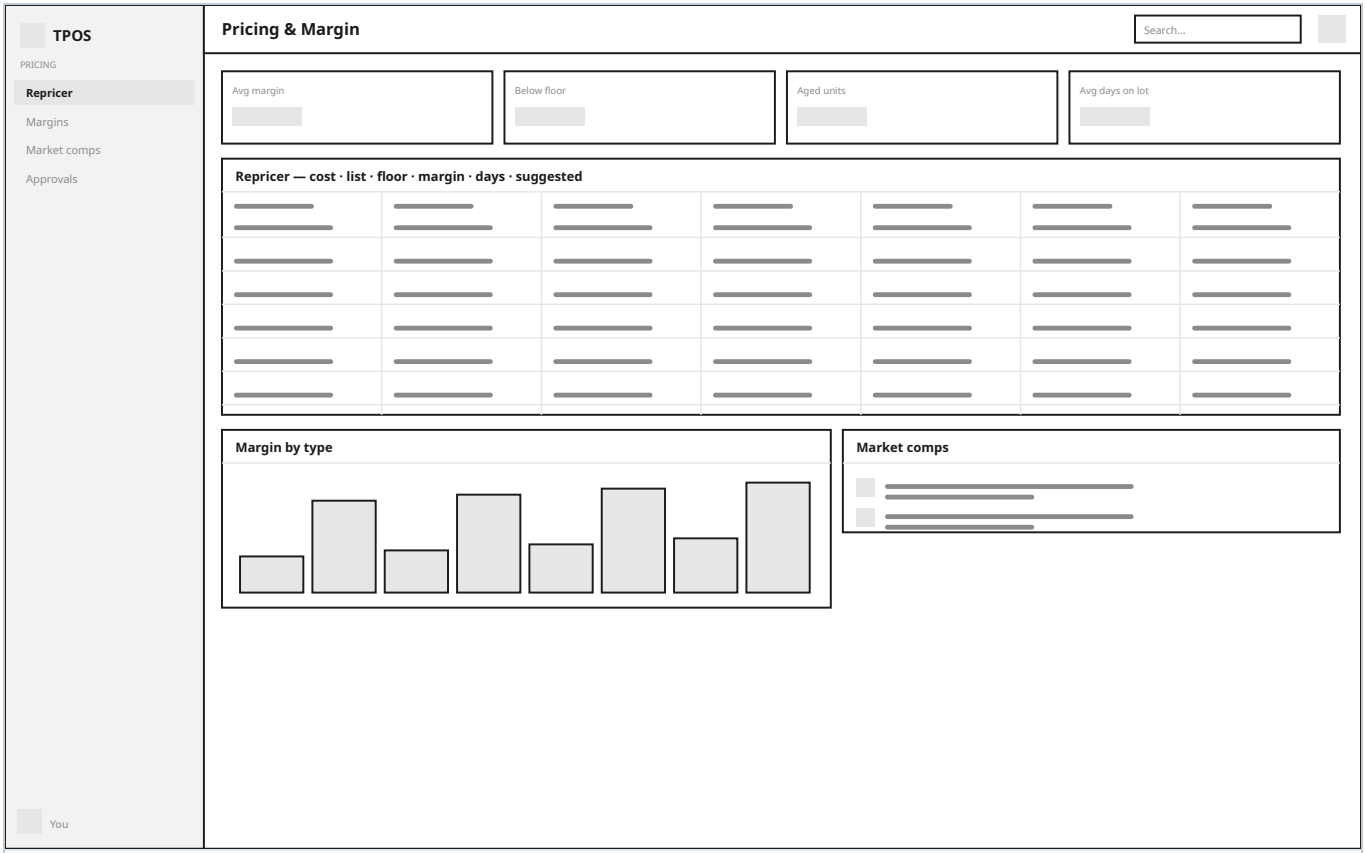
Wireframe — Sales Manager primary workspace (layout & IA only).

6.5 Pricing Analyst

Goal. Maximize margin and turn.

Functional requirements

- Repricer over available units: cost/list/floor/margin/days/demand with a suggested price & reason.
- Margin monitoring by type; aged-unit reprice prompts.
- Market comparables; price-change approval queue.



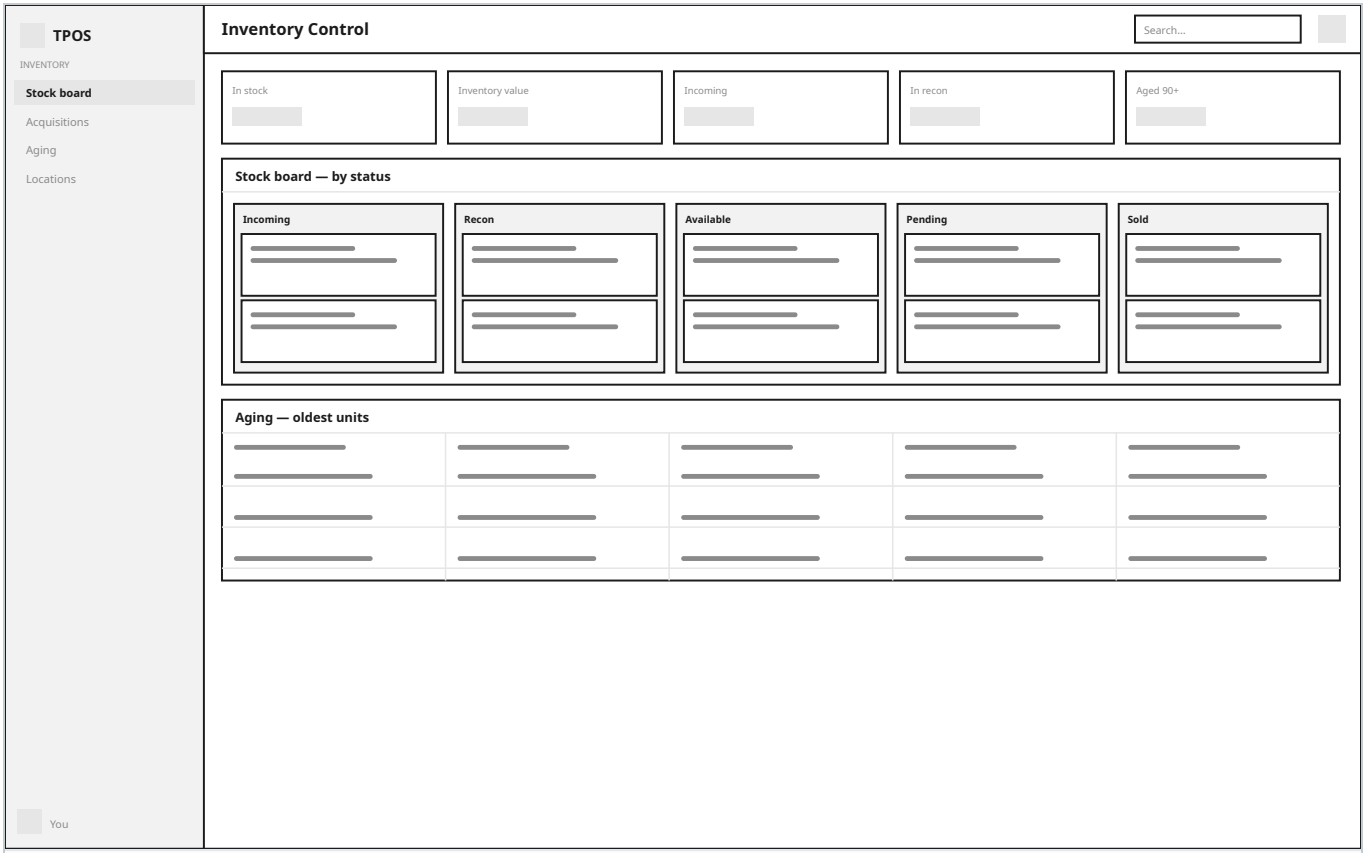
Wireframe — Pricing Analyst primary workspace (layout & IA only).

6.6 Inventory Manager

Goal. Source, recon, place and turn units.

Functional requirements

- Stock board by status (incoming→recon→available→pending→sold) and by location/lot.
- Acquisition intake with ETA & cost; push units into recon and onto the lot.
- Aging report and turn metrics; trigger reprice/clearance.



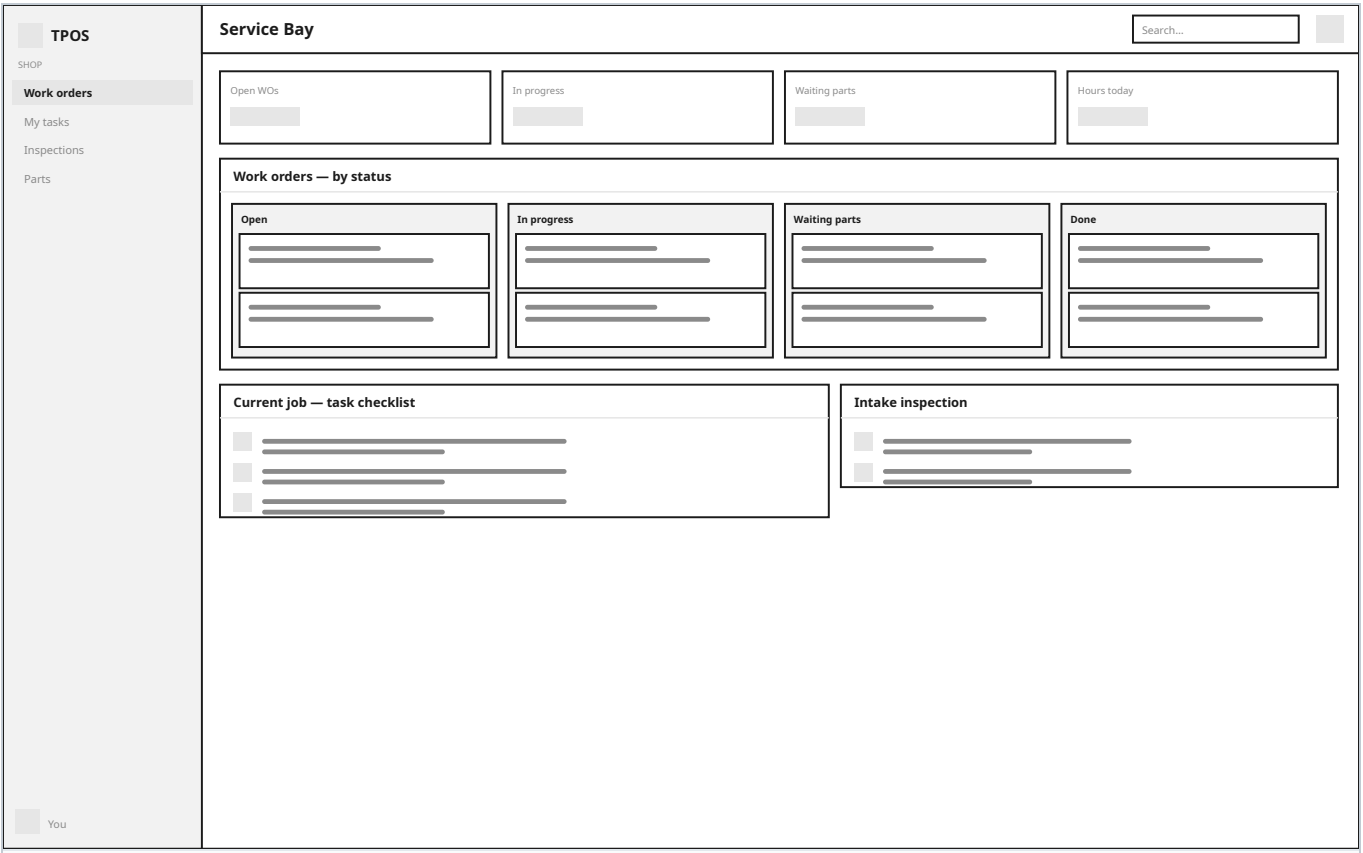
Wireframe — Inventory Manager primary workspace (layout & IA only).

6.7 Service Technician

Goal. Recondition and inspect units quickly.

Functional requirements

- Work-order board by status with hours-vs-estimate and parts cost.
- Per-job task checklist; intake inspection checklists (brakes/tires/lights/floor).
- Log hours, parts and photos against the unit.



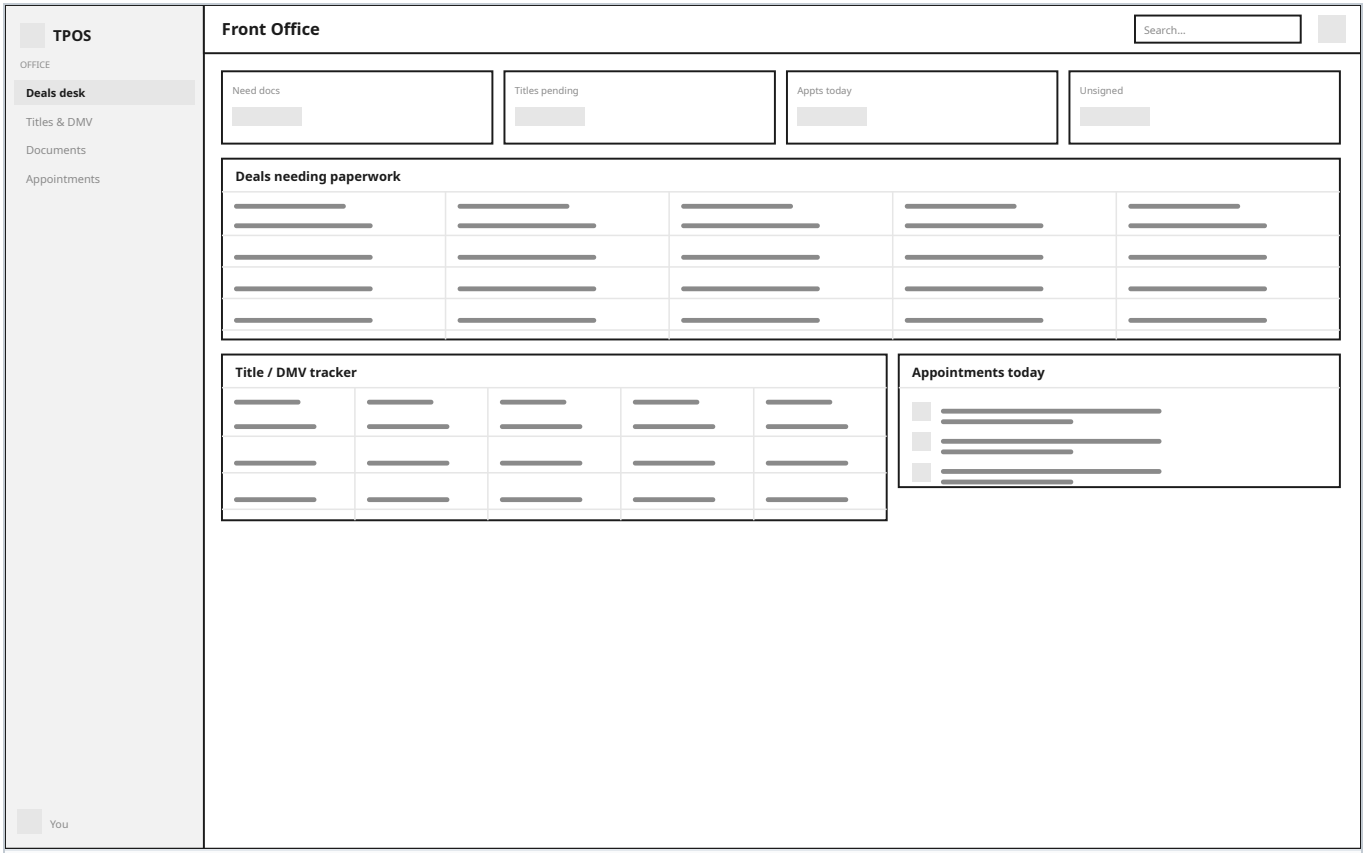
Wireframe — Service Technician primary workspace (layout & IA only).

6.8 Office / Titles & Admin

Goal. Keep paperwork clean and legal.

Functional requirements

- Deals-needing-documents queue with missing-doc flags (title, bill of sale, financing, insurance).
- Title / DMV tracker by unit (in hand / applied / pending / lien release) per state.
- Appointments & signings; document checklist & e-signature.



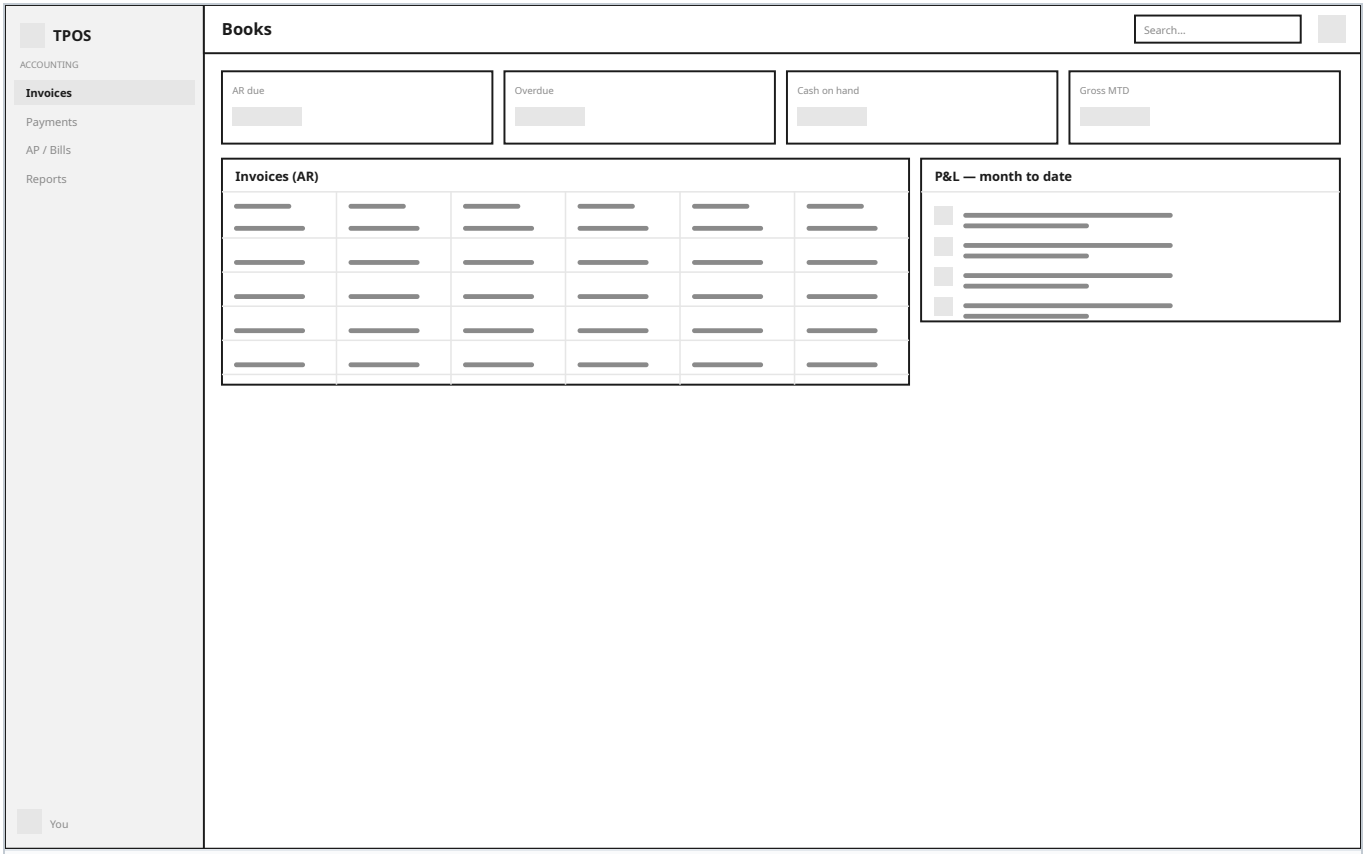
Wireframe — Office / Titles & Admin primary workspace (layout & IA only).

6.9 Bookkeeper / Accounting

Goal. AR/AP, cash and month-end.

Functional requirements

- Invoices (AR) with status (paid/due/overdue) and record-payment.
- AP / vendor bills; cash position; payments ledger.
- Month-end P&L (revenue, COGS, gross, expenses, net).
- Manual, on-demand **accounting export** — QuickBooks first (CSV + IIF), other systems later (Appendix I).



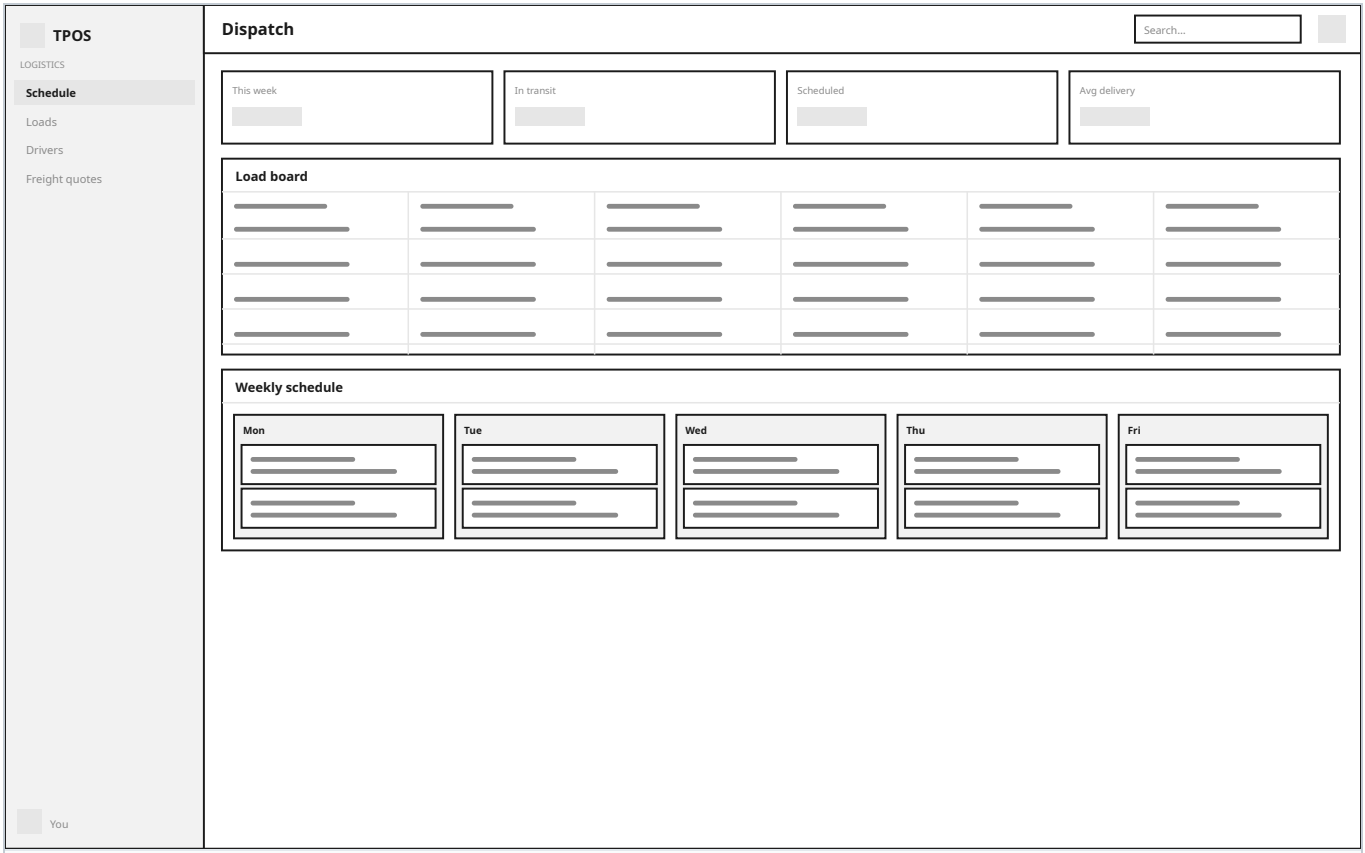
Wireframe — Bookkeeper / Accounting primary workspace (layout & IA only).

6.10 Delivery Dispatch

Goal. Move sold units to buyers.

Functional requirements

- Load board of units needing delivery with destination, carrier/driver and status.
- Weekly delivery schedule; assign drivers/carriers.
- Freight rate quotes by lane; in-transit tracking with ETA.



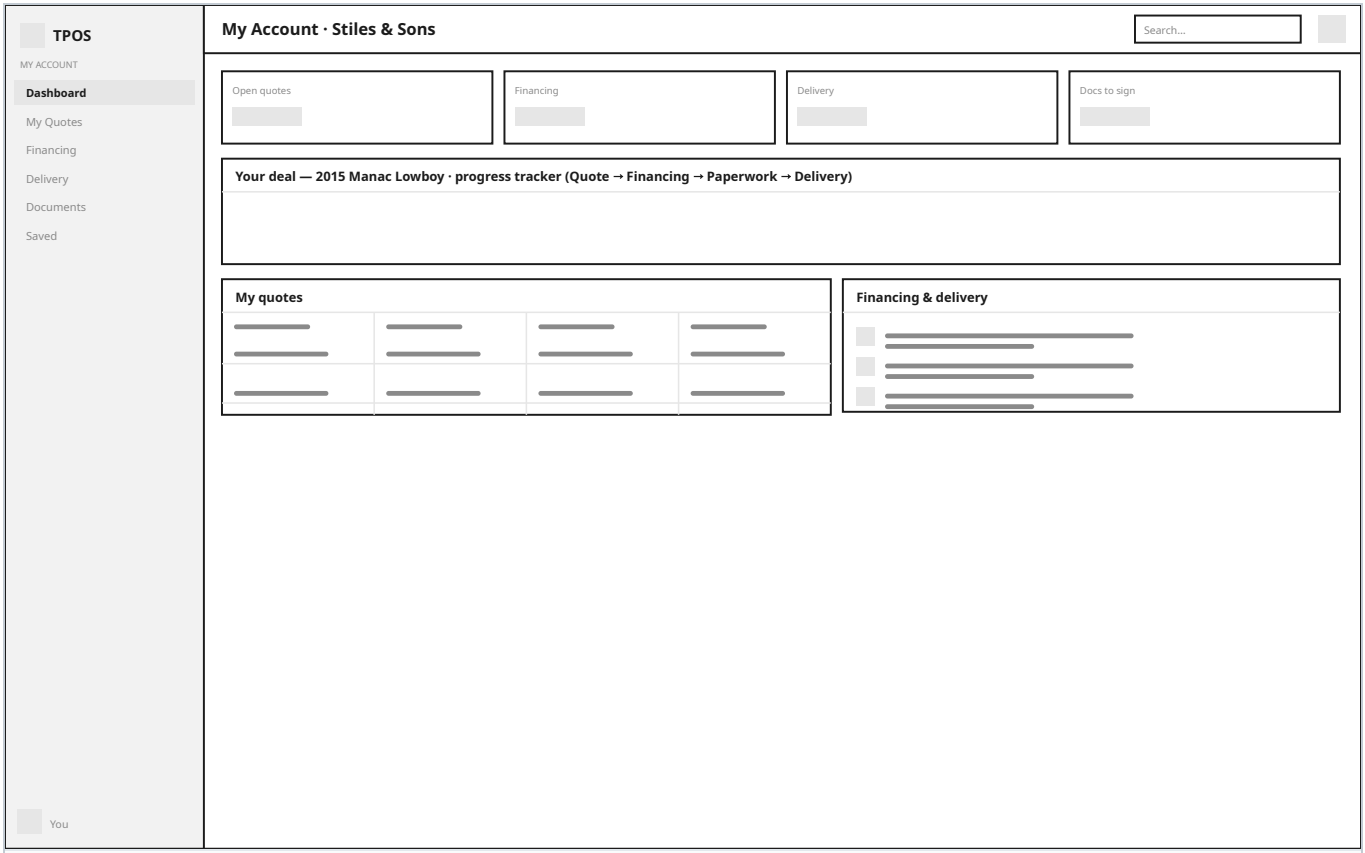
Wireframe — Delivery Dispatch primary workspace (layout & IA only).

6.11 Customer (Buyer) Portal

Goal. Buy with confidence, self-serve.

Functional requirements

- Deal progress tracker (quote → financing → paperwork → delivery).
- View/accept quotes; apply for financing and see decision status.
- Track delivery; review, e-sign and download documents; saved trailers.



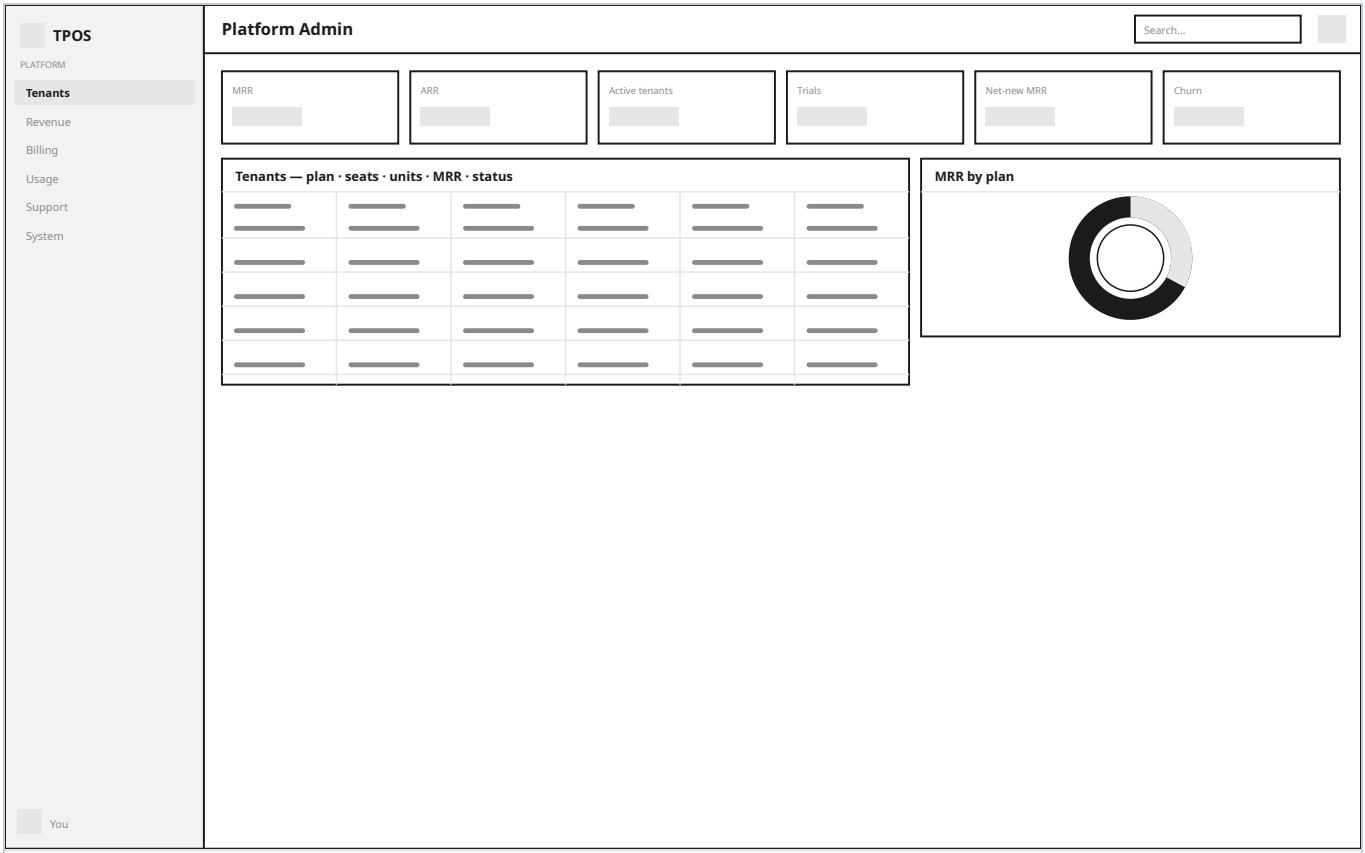
Wireframe — Customer (Buyer) Portal primary workspace (layout & IA only).

6.12 Platform Super-Admin

Goal. Operate the SaaS business (hosted mode).

Functional requirements

- Tenant directory with plan, seats, units, MRR and status; provision & manage.
- Revenue (MRR/ARR/net-new/churn), MRR-by-plan, trials & onboarding.
- Cross-tenant usage metering, support queue and system-health monitoring.



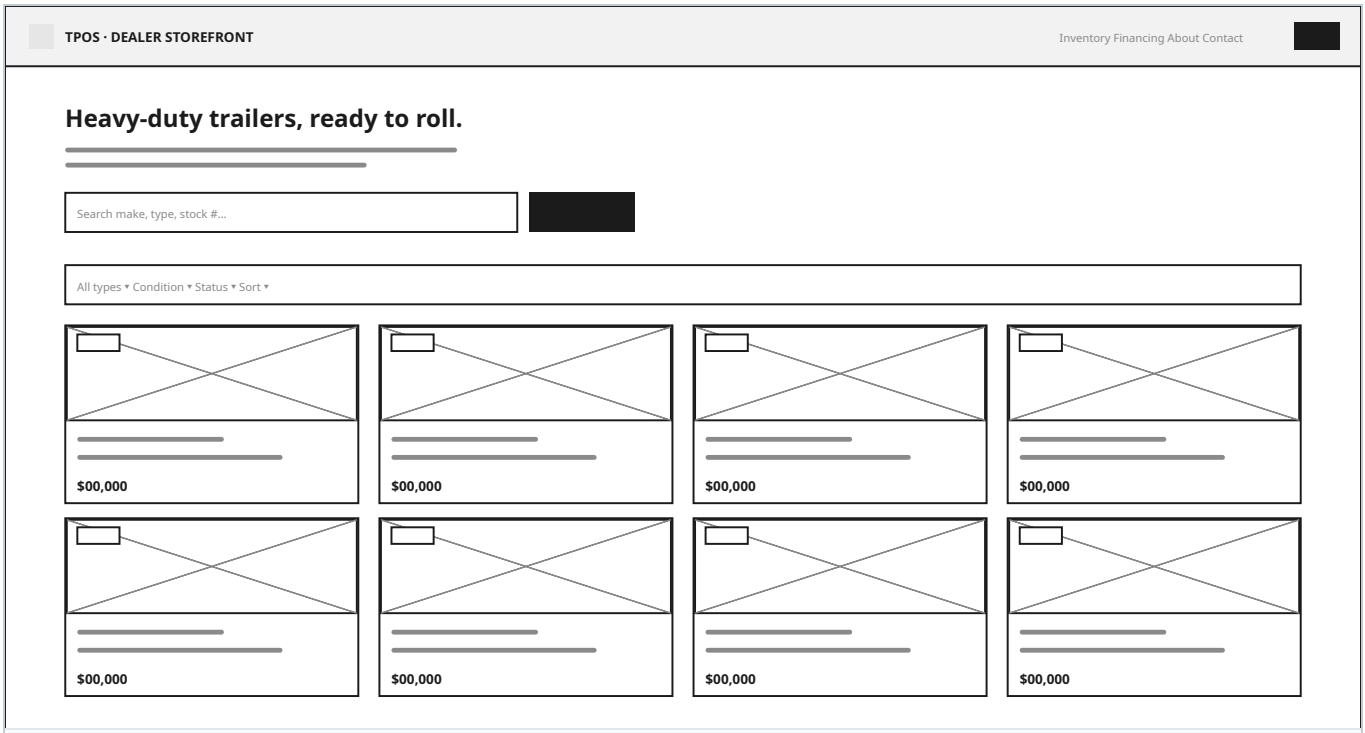
Wireframe — Platform Super-Admin primary workspace (layout & IA only).

7 · Public Storefront

Every tenant gets a branded, mobile-first public website auto-generated from its *available* inventory. It is the demand engine that feeds the Lead Desk.

Functional requirements

- Inventory grid with filter (type, condition, status), keyword search and sort (featured / price / year); each unit shows photos, key specs, price, location and a status badge.
- Deep-linkable, shareable detail pages per unit (full specs, photos, description) with status (Available / Pending / Sold).
- Lead capture: "Request a quote" and "Sell your trailer" forms create a **Lead** in the tenant's back office and notify staff; financing pre-qualification entry point.
- Informational pages (financing, about, contact) and tenant branding (logo, colors, phone, address).
- Units automatically appear/disappear as their status changes; optional syndication to external listing channels.



Public storefront — generated from available inventory; forms create leads in the back office.

8 · Cross-Cutting Capabilities

- **Global search** across units, leads, customers, deals, invoices and documents, scoped to the tenant and the user's permissions.

- **Notifications** (in-app + email/SMS) for new leads, approvals needed, overdue AR, delivery updates and title actions.
- **Activity log / audit trail** on every entity: status changes, price changes, discounts, payments, document signatures — who, when, why.
- **Comments & @mentions** on units, deals and work orders so roles hand off context.
- **Tasks & follow-ups** assignable to users, surfaced on each role's dashboard.
- **Document storage & e-signature** for titles, bills of sale, financing and delivery receipts.

9 · Reporting & KPIs

All dashboards derive from the shared record so figures reconcile across roles. Core KPIs the system must compute:

Domain	KPIs
Sales	Pipeline value, weighted forecast, win rate, average deal, units sold (period), revenue, gross profit, sales-cycle length
Inventory	Units in stock by status, inventory value & cost, average days on lot, aged units (90+), turn rate, by-location counts
Pricing	Average margin %, units below floor, margin by type, reprice impact
Marketing	Leads by source, cost per lead, first-response time, lead→quote→won conversion
Service	Open/in-progress/waiting work orders, recon cost & cycle time, hours utilization
Money	AR aging, AP due, cash position, gross margin, monthly P&L
Platform (operator)	MRR / ARR, net-new MRR, churn, trials & conversions, seats & units per tenant, usage, uptime

10 · Roles & Permissions Matrix

Access is role-based and tenant-scoped. A user may hold multiple roles (common in small dealers). Sample matrix (✓ = full, ◑ = own records, · = read-only, blank = none):

Capability	Owner	Lead	Sales	S.Mgr	Price	Inv	Svc	Office	Books	Disp	Cust
View inventory	✓	·	·	·	✓	✓	·	·	·	·	store
Edit price / floor	✓			◑	✓	·					
Work leads	·	✓	◑	✓							
Advance deals	·		◑	✓				·	·	·	own
Approve discount	✓			✓	◑						

Work orders	·					✓	✓				
Titles / documents	·		·					✓	·	·	own
Invoices / payments	·							·	✓		own
Schedule delivery	·		·			·		·		✓	·
Manage users / billing	✓										

The Platform Super-Admin operates above all tenants and is not on this per-tenant matrix.

11 · External Integrations

Integration	Purpose
Financing / lenders	Soft-pull pre-qualification, application submission, decision status into Deal & Customer portal
Listing syndication	Push available units to TruckPaper, Facebook Marketplace, Google; pull leads back
Title / DMV & e-sign	Title status, lien release, electronic signing of titles & bills of sale
Payments	Deposits, payoffs, ACH/wire/card; reconcile to invoices
Freight / carriers	Freight rate quotes, dispatch, in-transit tracking
Accounting export	Sync to QuickBooks / Xero (invoices, payments, journal entries)
Email & SMS	Lead notifications, customer comms, delivery/title updates
Platform billing	Subscription billing & metering for the SaaS operator (hosted mode)

12 · Non-Functional Requirements

Area	Requirement
Multi-tenancy	Strict per-tenant data isolation enforced at the data layer; no cross-tenant access possible by any query path.
Security	Authentication with sessions/SSO; role-based authorization on every action; encrypted secrets; audit log of sensitive actions; PII & financing data protected.
Availability	Hosted SLA target 99.9%; storefront cached/CDN-served; graceful degradation if back-office services are down.
Performance	Dashboards load < 2 s on typical tenant volumes; storefront fast on mobile; search responsive.
Scalability	Hundreds of tenants, tens of thousands of units & leads per tenant, without per-tenant degradation.
Portability	Same codebase deploys hosted (multi-tenant) and self-host (single-tenant) via configuration/license; no operator-only assumptions in tenant features.
Data & backups	Per-tenant export of all data; regular backups; tenant offboarding returns/erases data.
Observability	Logs, metrics, error tracking; per-tenant usage metering for billing; uptime & API latency dashboards (operator).
Accessibility & responsive	Internal tools usable on tablet; storefront fully responsive; WCAG-AA color/contrast for storefront.
Auditability	Immutable history of status/price/discount/payment/document events with actor, timestamp and reason.

13 · Acceptance Criteria

The rebuild is "done" when the following end-to-end scenarios pass for a tenant, with figures reconciling across roles:

1. **Acquire→list.** Inventory Manager adds an incoming unit; Service completes intake & recon; Pricing sets list/floor; status flips to *available* and the unit appears on the storefront and syndication.
2. **Lead→quote.** A storefront "Request a quote" creates a Lead in the Lead Desk within seconds, routes to a salesperson, who builds a Quote tied to the unit.
3. **Negotiate→approve.** A below-floor offer requires Sales Manager approval, which is logged; the Deal advances to financing.
4. **Finance→title→deliver.** Customer applies for financing in the portal and sees status; Office tracks title to "in hand"; Dispatch schedules and tracks delivery to "delivered."

5. **Book.** Bookkeeper issues the invoice, records payment, and the sale appears in revenue/gross KPIs that match the Owner dashboard.
6. **Operate (hosted).** Super-Admin provisions a new tenant, sees it billed, and watches MRR/usage update.

14 · Glossary

Floor price	The lowest price a unit may be sold at without manager approval; protects margin.
Days on lot	Days since acquisition; drives aging & reprice decisions.
Recon	Reconditioning — the service work to make an acquired unit retail-ready.
Pipeline (value)	Sum of open-deal values; "weighted" multiplies each by win probability.
AR / AP	Accounts receivable (money owed to the dealer) / payable (money the dealer owes).
Syndication	Auto-publishing inventory to external listing channels.
Tenant	One dealership's isolated instance of the platform.
MRR / ARR	Monthly / annual recurring revenue (operator metric).

Appendix A · Data Dictionary & Relational Schema

Recommended target: **PostgreSQL** (hosted / multi-tenant) with **Row-Level Security**; **SQLite** for single-tenant self-host installs behind the same data-access layer. Conventions applied to every tenant-scoped table:

- Primary key `id uuid`; audit columns `created_at`, `updated_at timestamptz`; optional `deleted_at` for soft delete.
- `tenant_id uuid NOT NULL → tenants(id)` on every business table, enforced by an RLS policy `USING (tenant_id = current_setting('app.tenant_id')::uuid)` — no query path can cross tenants. (Self-host keeps the column for parity and drops the policy.)
- Money as `numeric(12,2)`; flexible attributes as `jsonb`; enums as Postgres enum types / CHECK constraints (see below).
- Every mutation that matters (status, price, discount, payment, signature) writes a row to `activities` (immutable audit log).

Table	Key columns (type)	Relationships & indexes
tenants	name, plan(enum), status(enum), domain, branding(jsonb), billing_ref, lots(jsonb)	root of isolation; platform-managed
users	name, email, password_hash, roles(text[]), lot_scope(text[]), active(bool), last_login	→ tenants; RBAC subject; uniq(tenant_id,email)
units (inventory — the spine)	stock_no, type, year, make, length, axles, capacity, condition, status(enum), lot_id, cost, list_price, floor_price, acquired_at, sold_at, views, lead_count, specs(jsonb)	uniq(tenant_id,stock_no); idx(tenant_id,status); → lots
unit_photos	unit_id, url, sort, is_cover(bool)	→ units (→ object storage)
leads	name, company, source, status(enum), value, phone, email, lost_reason	→ units (interest), → users (owner)
customers	name, company, phone, email, portal_user_id	buyer accounts; → users (portal)
deals	stage(enum), value, probability, financing_status	→ customers, → units, → users (salesperson)
quotes / **quote_lines**	quotes: total, valid_until, status · lines: kind(enum: price|prep|freight|tax|fee), label, amount	quotes → deals/units; lines → quotes
work_orders / **wo_tasks**	WO: type, status(enum), hours_est, hours_actual, parts_cost, opened_at, closed_at · task: label, done(bool), sort	WO → units, → users (tech); task → work_orders
invoices	kind(AR|AP), amount, status(enum), issued_at, due_at, note, vendor	→ customers / deals / units (nullable)
payments	amount, method, paid_at, reference	→ invoices; idempotent on reference
titles	status(enum), state, lien_holder, released_at	uniq(unit_id) → units

documents	kind, url, signed_at, signer, sign_request_id	→ deals / units; e-signature
deliveries	origin, destination, carrier, driver, status(enum), eta, freight_cost	→ deals, → units
activities (audit log)	entity_type, entity_id, actor_id, action, detail(jsonb), at	append-only; idx(tenant_id,entity_type,entity_id)
tasks / **notifications**	tasks: assignee_id, title, due_at, done, link(entity) · notif: user_id, kind, payload(jsonb), read_at	cross-cutting; → users

Enumerations

Enum	Values
unit.status	`incoming · recon · available · pending · sold`
lead.status	`new · working · quoted · won · lost`
deal.stage	`lead · quoted · negotiation · financing · delivery · won · lost`
work_order.status	`open · in_progress · waiting_parts · done`
invoice.status	`paid · due · overdue`
title.status	`in_hand · applied · pending · lien_release`
delivery.status	`scheduled · en_route · delivered`
tenant.plan / .status	`starter · growth · enterprise · license` / `active · trial · licensed · suspended`

Platform control plane (hosted mode only — separate schema, no tenant RLS)

Table	Key columns
subscriptions	tenant_id, plan, mrr, seats, started_at, status, billing_provider_ref
usage_metrics	tenant_id, period, units, leads, storefront_views, api_calls (for metering & billing)
support_tickets	tenant_id, subject, status, priority, opened_at
license_keys	key, owner, plan, seats, expires_at (validated by self-host installs)

Appendix B · API Reference

REST / JSON. **Namespaces:** `/api/v1/*` authenticated back-office (tenant from session/subdomain, every query tenant-scoped) · `/api/v1/portal/*` customer portal · `/api/public/*` storefront (no auth, tenant by host) · `/api/platform/*` operator control plane (super-admin, cross-tenant) · `/api/webhooks/*` inbound integrations. RBAC per endpoint (the §10 matrix); state-machine changes use explicit `…/transition` actions (validated + audited), not arbitrary PATCH; lists accept `?q=&status=&sort=&page=&limit=`; money/transition writes accept an `Idempotency-Key` header.

Auth & session

```
POST  /api/v1/auth/login            GET  /api/v1/auth/me
POST  /api/v1/auth/logout           POST /api/v1/auth/sso/callback
POST  /api/v1/auth/password/reset
```

Inventory & pricing

```
GET   /api/v1/units                 list/filter (type,status,location,aged)
POST  /api/v1/units                 intake / acquire
GET   /api/v1/units/:id             full record ("all lenses")   PATCH /api/v1/units/:id
POST  /api/v1/units/:id/transition  incoming→recon→available→pending→sold (guarded)
POST  /api/v1/units/:id/photos      GET /api/v1/units/:id/timeline    GET /api/v1/units/aging
PATCH /api/v1/units/:id/price       set list/floor (logged; may require approval)
GET   /api/v1/pricing/repricer      GET /api/v1/pricing/comps?unit=:id
GET   /api/v1/pricing/approvals     POST /api/v1/pricing/approvals/:id/decide
```

Leads, customers, deals, quotes

```
GET/POST /api/v1/leads              GET/PATCH /api/v1/leads/:id
POST  /api/v1/leads/:id/assign      POST /api/v1/leads/:id/convert  →deal
GET   /api/v1/sources               GET/POST /api/v1/campaigns
GET/POST /api/v1/customers          GET/PATCH /api/v1/customers/:id
GET/POST /api/v1/deals              GET/PATCH /api/v1/deals/:id
POST  /api/v1/deals/:id/stage       advance pipeline
POST  /api/v1/deals/:id/discount    POST /api/v1/deals/:id/approve  (manager RBAC)
GET/POST /api/v1/quotes             POST /api/v1/quotes/:id/send | /accept
GET   /api/v1/forecast              GET /api/v1/team/leaderboard
```

Service · accounting · titles · delivery

```
GET/POST /api/v1/workorders         POST /api/v1/workorders/:id/status
PATCH /api/v1/workorders/:id/tasks/:t   POST …/hours  …/parts  …/photos
GET/POST /api/v1/invoices           POST /api/v1/invoices/:id/payments (idempotent)
GET/POST /api/v1/bills              GET /api/v1/accounting/pnl?period=   POST /accounting/export
GET/PATCH /api/v1/titles/:unitId    GET/POST /api/v1/documents   POST /documents/:id/sign
GET/POST /api/v1/deliveries         POST /api/v1/deliveries/:id/status   POST /deliveries/quote
GET/POST /api/v1/appointments
```

Cross-cutting & tenant admin

```
GET   /api/v1/search?q=            GET /api/v1/notifications  POST …/:id/read
GET/POST /api/v1/tasks             GET /api/v1/activity       GET /api/v1/reports/:kpiSet
GET/POST /api/v1/users             PATCH /api/v1/users/:id (roles, lot scope)
GET/PATCH /api/v1/tenant/settings  branding · lots · config · billing
```

Storefront (public) & customer portal

```
GET   /api/public/inventory        available units (filter/search/sort)
GET   /api/public/inventory/:stock  detail (deep-linkable)
POST  /api/public/inquiry          creates a Lead + notifies   ← implemented in prototype
POST  /api/public/financing/prequalify
GET   /api/v1/portal/me            GET /api/v1/portal/deals
GET   /api/v1/portal/quotes/:id    POST …/accept
POST  /api/v1/portal/financing/apply  GET …/status
GET   /api/v1/portal/delivery/:id  GET /api/v1/portal/documents  POST …/:id/sign
GET/POST /api/v1/portal/saved
```

Platform control plane (hosted) & webhooks

```
GET/POST /api/platform/tenants     PATCH /api/platform/tenants/:id (plan/status)
GET   /api/platform/revenue        GET /api/platform/usage    GET /api/platform/billing
GET   /api/platform/support        GET /api/platform/health   POST /api/platform/license/verify
POST  /api/webhooks/financing      lender decision → Deal/portal
POST  /api/webhooks/payments       settled → reconcile invoice
POST  /api/webhooks/freight        carrier status → delivery
POST  /api/webhooks/syndication    listing-site lead → Lead
POST  /api/webhooks/title          DMV/title callback
```

Appendix C · Performance & Scaling

TPOS is **database-bound CRUD**: requests spend their time waiting on Postgres, not on application code. The performance and tenant-density wins therefore live in the **data layer and the connection pool**, not in an exotic runtime or premature sharding. This appendix is one optimization profile; apply it only to the degree the product needs.

Define the dimension first. "High performance" is not one thing, and the lever order changes with it. Decide which of these dominates before optimizing — over-investing in the wrong one is wasted complexity.

If the goal is…	Dominant levers, in order
p99 read latency (dashboards feel instant)	Materialized read models → cache hot reads → `tenant_id`-leading indexes → read replicas
Write / transaction throughput	Index discipline → prepared statements & batching → hash-partition hot tables → pool sizing
Tenants per server (density)	PgBouncer transaction pooling → edge-offload the storefront → shared-schema low footprint → async runtime

C.1 Indexing & query design — the foundation (and what makes RLS cheap)

- Every hot index **leads with `tenant_id`**, then the query's predicates: `(tenant_id,status)`, `(tenant_id,stock_no)`, `(tenant_id,due_at)`, `(tenant_id,stage)`, etc.
- **Keep Row-Level Security.** With the right composite index the planner pushes the policy predicate into the index scan, so RLS is cheap (reported order-of-magnitude: ~0.3 ms policy evaluation at 50 M rows / 10 K tenants; ~1–5% vs. app-level filtering). **The 100× penalty comes from a missing `tenant_id`-leading index, not from RLS itself.** Database-enforced isolation is worth the few percent — one cross-tenant leak is existential, and it protects you even when application code has a bug.
- Eliminate N+1s; use prepared statements; keep working sets index-resident.

C.2 Partitioning — secondary, and use HASH not list

- Partitioning is a lever only for the largest tables (e.g. `activities`, `units` at very high volume); the composite index above does most of the work first.
- With thousands of tenants, partition by **`HASH(tenant_id)` into a fixed number of partitions** (e.g. 16–64) for cache locality and scan pruning. **Do NOT list-partition one-per-tenant** — thousands of partitions blow up planner time and DDL. Time-range sub-partitioning suits the audit log.

C.3 Connection pooling — the real density lever

- Postgres is process-per-connection (~5 MB + context-switch per connection), so density comes from **PgBouncer in transaction-pooling mode** multiplexing many clients onto a small pool sized to roughly **3–5 backend connections per CPU core**.

- **Gotcha that interacts with RLS:** under transaction pooling a session-level `SET app.tenant_id` does not persist across statements. Set the tenant **per-transaction** with `SET LOCAL app.tenant_id = …` (or `set_config('app.tenant_id', …, true)`) so RLS still applies. Also avoid session-scoped prepared-statement / session-feature assumptions in transaction mode.

C.4 Read path — precompute the dashboards (CQRS-lite)

- The KPI dashboards (§9) aggregate across many rows. Precompute them into **materialized views / rollup tables** refreshed incrementally by the background worker, so a dashboard load is an O(1) indexed read, not a per-request fan-out join. This is the single biggest internal-latency win.
- Cache hot reads (Redis / Dragonfly or in-process) with event-driven invalidation on writes; route all dashboard/report traffic to **read replicas**.

C.5 Storefront at the edge

The public storefront's "available inventory" is the highest-volume, most cacheable traffic. Serve it from a **CDN / ISR edge**, invalidated when a unit's status changes. This removes the largest read load from the origin entirely and is often the cheapest way to raise effective tenants-per-server.

C.6 Runtime — a minor lever for DB-bound work

Framework benchmarks show per-request gaps **collapse once Postgres is in the loop** (compiled runtimes dominate only the compute-bound plaintext/JSON rounds). For DB-bound CRUD you will not get throughput from switching language — choose the runtime for its **concurrency model and your team**, not per-query speed. Where it touches density: an async / light-concurrency runtime (**Go, .NET, Node, or Elixir** for connection-heavy/real-time) holds more in-flight requests per box than a process-per-worker Python/Ruby setup. **Rust is not required** here and its productivity cost rarely pays back on this workload.

C.7 Scaling ladder — earn each step

1. Vertical scaling + PgBouncer (handles a large share of workloads on its own).
2. Add read replicas for the read/report load.
3. Hash-partition the few largest tables.
4. **Only** once a single primary is genuinely exhausted (commonly hundreds of GB+), shard with **Citus** co-located by `tenant_id`. Keep the schema partition-ready (`tenant_id` on every table) so this migration is cheap — but **defer it**; vanilla Postgres + replicas goes much further than teams expect.

Caveat — treat the numbers as order-of-magnitude. The RLS timing figures come from a single practitioner benchmark and the single-node size thresholds are partly vendor framing. Use them for intuition; **benchmark on your own schema, queries and data** before treating any figure as a constant. Sources: practitioner RLS-at-scale benchmarks, PgBouncer pooling guides (connection-cost & per-core sizing), single-node-Postgres scaling write-ups, and the TechEmpower framework benchmarks (database-query rounds).

Appendix D · Architecture Decisions & Roads Not Taken

Every significant fork weighed for the rebuild — the options considered, what was chosen, what was rejected and why. Decisions are advisory; the build team owns the final call. Several were **revised mid-review as evidence came in** — those are flagged (REVISED) and recorded honestly rather than quietly replaced. Bracketed numbers reference the sources in §D.2.

#	Decision	Options considered	Chosen	Roads not taken — reasoning
1	Prototype persistence	Flat JSON file · real database	JSON file + in-browser mock	The prototype is a UI/IA demo; only the storefront lead endpoint is live. A real DB was out of scope for a front-end mock.
2	Production database	PostgreSQL · document/NoSQL · MySQL · SQLite-only	**PostgreSQL** (hosted) + SQLite per self-host tenant	NoSQL rejected — the domain is intensely relational (one-record-many-lenses = foreign keys), needs transactions (booking a sale) and joins. MySQL viable; Postgres preferred for RLS, jsonb, partitioning, extensions. SQLite-only rejected for hosted (concurrency) but ideal for a single self-host tenant. [1]
3	Multi-tenant isolation	Shared schema + RLS · schema-per-tenant · database-per-tenant · app-level filtering only	**Shared schema + RLS**, `tenant_id` on every table	DB-per-tenant rejected — poor density, heavy ops. Schema-per-tenant rejected — migration/ops complexity at scale. App-filtering-only rejected — one forgotten `WHERE` leaks data; isolation belongs in the database. RLS gives DB-enforced safety at ~1–5% when indexed. [1][2][3][4]
4	Service topology	Modular monolith · microservices	**Modular monolith** (one deployable)	Microservices rejected — the self-host requirement wants one artifact, the team is small, and network hops hurt DB-bound latency. Extract a service later only if a piece proves it needs it.
5	App framework (pragmatic profile)	Django/DRF · Rails · NestJS+Next.js · Go · .NET · Elixir	**Django/DRF** (lead) or **NestJS+Next.js** (JS-first)	Go/.NET/Rust rejected as the default — more boilerplate for CRUD/admin and no free admin plane. Chosen for batteries-included CRUD, migrations, RBAC, Postgres-first tooling, and clean self-host packaging.
6	Media storage	S3-compatible object storage (MinIO self-host) · blobs in Postgres	**S3-compatible** object storage	Blobs-in-DB rejected — bloats the database and slows backups/replication; photos & signed documents belong in object storage.
7	Storefront rendering	Edge/CDN (ISR) · in-app SSR · SPA	**SSR + edge-cache** available inventory	Pure SPA rejected for the public site — SEO & first-paint matter. Internal

				dashboards stay SPA/API (or SSR-with-enhancement).
8	Runtime under *performance-primary* **REVISED**	Rust · Go · .NET · Elixir · keep pragmatic	Async/light-concurrency (**Go/.NET/Elixir**); **Rust not required**	Initially proposed Rust for raw throughput. Evidence: framework gaps **collapse once Postgres is in the loop**; Rust leads only compute-bound rounds. For DB-bound CRUD the runtime is a minor lever — choose for concurrency model + team, not per-query speed. [9]
9	RLS under *performance-primary* **REVISED**	Keep RLS (indexed) · move isolation to app/partitioning for speed	**Keep RLS** + `tenant_id`-leading composite indexes	Initially suggested moving isolation out of RLS for speed. Evidence: RLS ~0.3 ms at 50 M rows / 10 K tenants *with the right composite index*; the 100× penalty is the **missing index**, not RLS. Keep it — the safety is worth ~1–5%. [2][3]
10	Horizontal sharding **REVISED**	Citus early (ease later migration) · single-node + replicas, defer	**Single node + replicas; defer Citus**, keep schema shard-ready	Initially put Citus "on the table." Evidence: vanilla Postgres + pooling handles most workloads under ~500 GB; replicas/partitioning extend into the terabytes before sharding is warranted. Defer until one primary is genuinely exhausted. [5][6]
11	Partitioning	HASH(tenant_id) fixed N · list/partition-per-tenant	**HASH(tenant_id)** into 16–64 partitions (large tables only)	Partition-per-tenant rejected — thousands of tenants blow up planner time & DDL. Partitioning is a *secondary* lever after the composite index. [6]
12	Connection management	PgBouncer transaction pooling · session pooling · none	**PgBouncer (transaction mode)** ~3–5/core + `SET LOCAL` tenant	No/session pooling rejected for density — process-per-connection (~5 MB each). Transaction mode requires `SET LOCAL app.tenant_id` per-transaction so the RLS variable survives (session `SET` silently breaks under it). [7][8]
13	Data access (perf paths)	Heavy ORM · thin typed SQL	**Thin typed SQL** (sqlx/sqlc/Dapper/Ecto) on hot paths	Heavy ORM rejected on hot paths — per-query overhead and hidden N+1s. ORM is fine for cold CRUD.
14	Dashboard read path	Per-request aggregation · materialized read models	**Materialized views / rollups** (CQRS-lite) + replicas + cache	Per-request big-join aggregation rejected for dashboards — precompute and serve an O(1) indexed read.

D.1 What we changed our minds about (and why)

Three decisions from the first "performance-first" pass were corrected once benchmark evidence was reviewed — recorded here so the reasoning is auditable, not lost:

- **#8 — Rust is not the lever.** For DB-bound CRUD, runtime choice barely moves throughput; the language win is real only on compute-bound paths. [9]

- **#9 — Don't drop RLS for speed.** The cost is the missing `tenant_id`-leading index, not the policy; keep DB-enforced isolation. [2][3]
- **#10 — Don't shard early.** A single Postgres primary + replicas + partitioning goes much further than expected; defer Citus. [5][6]

D.2 References & evidence quality

Sources consulted, with their nature flagged. **Several are vendor or single-practitioner sources; all numeric figures are order-of-magnitude guidance — benchmark on your own schema, queries and data before treating any as a constant.**

#	Source	Nature	Informs
1	PostgreSQL docs — Row Security Policies	Official documentation	RLS canonical reference (#2,#3)
2	RLS-at-scale benchmark (DEV Community)	Single-practitioner benchmark	~0.3 ms at 50 M/10 K with `tenant_id`-leading index; missing index = 100× (#3,#9)
3	RLS overhead write-up (Wellally)	Practitioner	~1–5% vs app-level filtering; planner push-down (#3,#9)
4	Tenant-isolation rationale (OneUptime); Crunchy Data RLS-for-tenants	Vendor / practitioner	DB-enforced isolation protects against app bugs (#3)
5	Single-node Postgres scaling (Velodb)	Practitioner / vendor	Vertical + pooling under ~500 GB; OpenAI on Postgres; replicas+partitioning to TB (#10)
6	Citus multi-tenant sharding docs & blog	Vendor framing	Shard by `tenant_id`, co-location; "~100 GB" threshold (#10,#11)
7	Connection scaling (PlanetScale); sizing (Akamai)	Vendor	Process-per-connection cost; PgBouncer multiplexing; ~3–5 conns/core (#12)
8	"PgBouncer … fraught with peril" (JP Camara)	Practitioner deep-dive	Transaction-pooling gotchas; `SET LOCAL` / session-feature caveats (#12)
9	TechEmpower Framework Benchmarks	Independent benchmark	DB-query rounds collapse framework gaps; Rust leads only plaintext/JSON (#8)

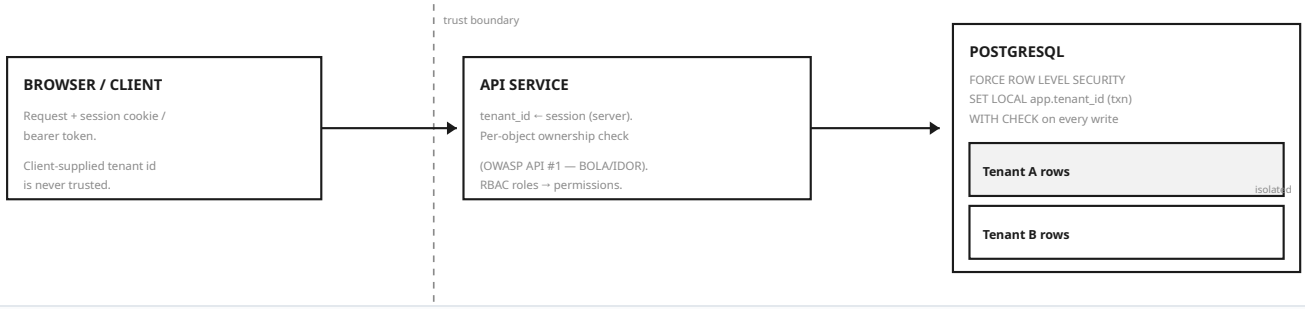
Appendix E · Security, Privacy & Compliance

A trailer dealer that **arranges or extends financing** is a "financial institution" under the Gramm-Leach-Bliley Act — which pulls the FTC **Safeguards Rule** (16 CFR Part 314) onto every tenant, and onto TPOS as their service provider. These are **binding legal requirements**, not optional hardening. This appendix maps the regime to platform controls and a threat model.

> **Not legal advice.** Items marked COUNSEL turn on facts a lawyer must confirm (whether a given dealer's financing model triggers GLBA, FTC-vs-CFPB privacy applicability, per-state titling/lien law, and contractual liability allocation). Figures and citations are accurate as researched; verify against primary text before relying on them.

E.1 Regulatory surface

Regime	Trigger	Owner	TPOS role
GLBA **Safeguards Rule** — 16 CFR 314	Dealer arranges/extends financing → "financial institution"	Dealer (tenant)	§314.4(f) **service provider** — must safeguard by contract, support audits
GLBA **Privacy Rule** — 16 CFR 313 / Reg P	Same	Dealer	Generate/deliver privacy notices; track opt-outs COUNSEL
FTC Red Flags Rule — 16 CFR 681	Dealer = "creditor" with "covered accounts"	Dealer	Supply identity-theft detection signals + logging
Safeguards breach reporting — 16 CFR 314.5	≥ 500 consumers' *unencrypted* info	Dealer files FTC ≤ 30 days from discovery	Detect, count affected, start the clock, assemble the report
State breach-notification (50 states + DC)	Compromise of defined PII	Per affected resident's state	Fan out per-jurisdiction notices; store residency to query the set
ESIGN / UETA — 15 U.S.C. 7001	Any e-signed finance/sale document	Platform e-sign flow	Consent gate + tamper-evident, reproducible records
ECOA / Reg B retention — 12 CFR 1002.12	Credit applications	Dealer	Honor 25-month retention floor in disposal policy



Defense in depth for the #1 risk — cross-tenant data disclosure. Tenant context is derived server-side, enforced at the API (object-ownership / BOLA check) and again in the database (RLS `FORCE` + per-transaction `SET LOCAL`). Neither layer trusts a client-supplied tenant id.

E.2 Safeguards Rule control map (16 CFR 314.4)

Each required element of the written information-security program, mapped to the platform control that satisfies it. The §314.6 partial exemption (< 5,000 consumers) relaxes four sub-elements for small dealers; TPOS implements the full set regardless.

§314.4 element	TPOS control
(a) Qualified Individual	Named security owner per tenant; TPOS may serve as the QI by contract for hosted tenants
(b) Written risk assessment	Tenant-facing risk-assessment template + periodic review prompt
(c)(1) Access controls	Least-privilege RBAC across the 12 roles; field-level masking of PII / title / payment data
(c)(2) Data inventory	Catalog of systems/fields holding customer info (this spec + data dictionary)
(c)(3) **Encryption** in transit & at rest	TLS everywhere; encrypted volumes; column-level encryption / tokenization for tokens & PII
(c)(4) Secure development	Secure SDLC; dependency & secret scanning in CI
(c)(5) **MFA**	MFA required on every login (mandatory for admin / title / payment roles)
(c)(6) **Secure disposal**	Retention engine: default purge of unused PII ≤ 2 years, overridden by legal-hold floors (ECOA 25 mo., title/finance records)
(c)(7) Change management	Reviewed, audited deploy pipeline; migration lint gates (RLS present, see E.4)
(c)(8) **Monitoring / logging**	Immutable, append-only audit log of who-did-what-to-which-record-when, incl. tenant_id
(d) Testing	Annual penetration test + vulnerability assessment ≥ every 6 months (absent continuous monitoring)
(e) Training	Security-awareness training; qualified security staff
(f) **Service-provider oversight**	The clause that binds TPOS: contractual security commitment, right to assess, breach-cost allocation

(g) Keep current	Re-evaluate program on testing results, material change, new threats
(h) Written incident-response plan	Documented IRP (roles, comms, remediation, post-mortem) wired to E.5
(i) Annual board report	QI's written annual report — exportable from the platform

Liability. Primary duty is the dealer's, and using a provider does not relieve it (§314.4(f)). But the FTC *has* acted directly against auto-dealer software providers (2019 settlement), so TPOS carries real exposure and allocates it by contract (MSA/DPA). COUNSEL

E.3 Privacy, e-signature & breach response

- **Privacy Rule.** The dealer issues the notice + opt-out; TPOS generates/delivers notices and tracks opt-outs. The §313.13 **service-provider exception** (a contractual use-restriction) is what lets the dealer share customer NPI with TPOS without an opt-out — so that clause must be in the contract. *Note: privacy rulemaking splits FTC (vehicle dealers) vs CFPB Reg P (others) — cite FTC 16 CFR 313 for dealers.* COUNSEL
- **E-signature (ESIGN/UETA).** Capture intent-to-sign; run the consumer-consent gate (affirmative consent + demonstrated ability to access the electronic form + the required pre-consent disclosures + a withdrawal mechanism); store tamper-evident, reproducible records (signer identity, timestamp, IP, document hash). **Title documents are carved out** — UETA §3 and many state codes exclude documents of title; treat titling as per-DMV, not generic e-sign.
- **Breach response.** Instrument detection to count affected consumers and whether data was encrypted; auto-start the **≤ 30-day FTC clock** (16 CFR 314.5) and fan out **state notifications by the affected resident's state**. Capture residency in the data model so the per-state affected set is queryable — the same per-jurisdiction pattern as titling.

E.4 Threat model — STRIDE × asset

Highest-priority cells shaded conceptually below; **Information disclosure × tenant data** (cross-tenant leak) is the single dominant risk.

Asset \ STRIDE	Spoofing	Tampering	Repudiation	Info disclosure	DoS	Elevation
Tenant business data	—	RLS WITH CHECK	Audit log	**RLS + API authz ◆**	Rate limit	FORCE RLS; non-owner role
Staff sessions	**Cookie flags, MFA ◆**	Signed/rotated	Audit log	HttpOnly/Secure	Throttle login	Re-auth on priv change
Portal / API tokens	Short-lived, scoped	Signature verify	Token id in log	No token in logs	Per-token limit	Scope = role
Payment tokens	—	**Tokenize ◆**	Audit log	Column encryption	—	Role-masked

Titles / PII	—	Integrity hash	Audit log	Encrypt + mask	—	Field-level authz
Uploaded files	—	Magic-byte check	Audit log	Off-webroot store	Size limit	Re-encode images
Public storefront	—	Read-only view	—	Published view only	**Edge cache ◆**	—
Audit log itself	—	**Append-only ◆**	n/a	Restricted read	—	Separate write role

E.5 Controls checklist (hard gates)

Tenant isolation — the #1 risk

- App connects as a **non-owner, non-superuser, non-`BYPASSRLS`** role.
- `FORCE ROW LEVEL SECURITY` on every tenant table.
- `SET LOCAL app.tenant_id` per transaction — never session `SET` under PgBouncer transaction pooling.
- `WITH CHECK (tenant_id = …)` on every write policy (block insert-as-wrong-tenant).
- Migration lint: every tenant table has RLS enabled *and* a policy.
- Derive tenant_id from session/token server-side; **never** from a client param (OWASP API #1, BOLA/IDOR). UUID resource ids.
- **CI negative test:** tenant A cannot read / update / delete / insert-as tenant B — at the DB *and* API layer; fail the build on any leak.

AuthN / AuthZ (OWASP ASVS)

- Cookies: `HttpOnly`, `Secure`, `SameSite`, `__Host-` prefix; session id ≥ 64-bit entropy; regenerate on login; idle + absolute timeouts; server-side logout.
- Passwords: **Argon2id** (m=19 MiB, t=2, p=1); bcrypt ≥ 10 only for legacy.
- MFA; login throttle/lockout; safe reset (single-use, time-limited, no enumeration).
- Tokens: short-lived, scoped, signature/issuer/audience/expiry validated.
- CSRF: synchronizer or HMAC double-submit for cookie auth; custom header on the bearer API.
- **RBAC** (roles → permission sets) over **ABAC** (tenant_id + field sensitivity).

Cross-cutting

- Secrets in a managed KMS/secret store, never in VCS; rotate DB & token-signing keys.
- TLS in transit; encryption at rest for DB + object storage; column encryption / tokenization for payment tokens & PII.
- Immutable, append-only audit log (the Repudiation control).
- Rate limiting per IP / token / tenant on auth, API and upload.
- Server-side input validation & parameterized queries everywhere.
- Secure upload: magic-byte (not Content-Type) validation, UUID filenames, off-webroot, malware scan, image re-encode.
- SSRF allow-listing on any server-side URL fetch (block RFC1918 / link-local / 169.254.169.254; validate resolved IP).

E.6 Schema deltas this requires

To satisfy the above, the relational schema (Appendix A / `schema.sql`) needs: an **immutable** **`audit_log`** table (append-only, tenant-scoped); a **`consent_records`** table (e-sign consent + document hash + signer/timestamp/IP); a **residency field** on customers (state, to drive breach fan-out); and a **retention-policy** configuration (per record-type disposal floors vs the 2-year default). Payment instruments store **token + last4 + brand only** (see Appendix B / payments).

E.7 Primary sources

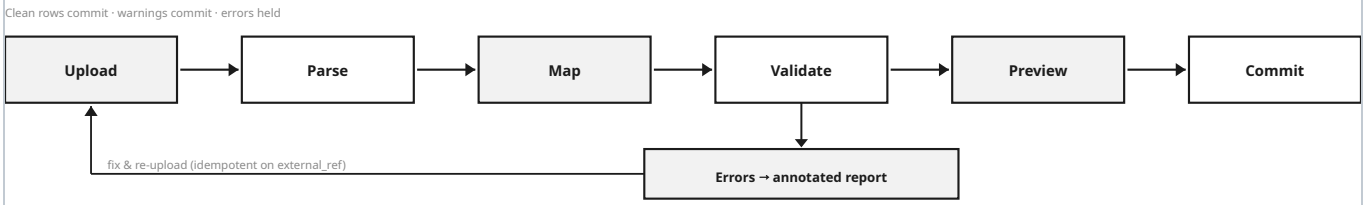
- FTC Safeguards Rule — 16 CFR 314.3–314.6 (eCFR; Cornell LII 314.4); FTC *"Safeguards Rule: What Your Business Needs to Know"* and *Automobile Dealers Safeguards FAQs*.
- Breach reporting — 16 CFR 314.5; FTC *"Safeguards Rule notification requirement now in effect"* (2024).
- Privacy Rule — 16 CFR Part 313 (esp. 313.13 service-provider exception); FTC *Privacy Rule & Auto Dealers FAQs*. Red Flags — 16 CFR 681.1 + App. A.
- ESIGN — 15 U.S.C. 7001(a)(c)(d), 7006; UETA §§2,3,12 (Uniform Law Commission).
- State breach laws — NCSL *Security Breach Notification Laws*. Retention — 12 CFR 1002.12 (Reg B).
- Threat model — OWASP API Security Top 10 (API1:2023 BOLA), OWASP ASVS Cheat Sheets (Session, Password Storage, CSRF, File Upload); PostgreSQL RLS docs; Supabase RLS guidance; Microsoft STRIDE.

Appendix F · Onboarding & Data Import

How a dealership goes from signup to live — and imports its existing book of inventory, customers and deals. Sales/CRM products have the **slowest time-to-first-value precisely because of import friction**, and B2B median activation is only ~37.5%; past **14 days** the great majority of signups have already churned. The import wizard *is* the onboarding bottleneck, and the highest-leverage thing to build well.

F.1 Tenant provisioning — one automated path, branches on plan tier

#	Step	Detail
1	Account + tenant_id	Self-serve and assisted requests enter the same registration service
2	Subdomain + branding	Logo, colors; custom domain is a later tier
3	First admin in central IdP	tenant_id / tier / roles stamped as claims
4	IaC provisioning	Schema, default roles — scripted, zero hand-config
5	Defaults	Lots/locations, deal stages, unit statuses, tax/fee defaults
6	Sample data	Seed explorable demo data the dealer can wipe before real import
7	Team invites	Role-based invitations
8	Billing — **async**	Non-blocking; dealer reaches a working dashboard before billing finishes
9	Land on import wizard	First in-app action; **activation event** = “first 10 units live + first deal created”



The import pipeline. Clean rows commit; rows with *warnings* still commit; rows with *errors* are held and returned as an annotated report for the fix-and-reupload loop. Every row is keyed on `external_ref` so re-uploading the same file upserts rather than duplicating.

F.2 Import pipeline specification

Column mapping

- Fuzzy **auto-map** to canonical fields (target ~95% auto-matched), with manual remap.
- Show, per canonical field, an inline **description + sample value**; allow split/merge (one “Customer Name” → first/last).

- **Persist the mapping profile** keyed to the dealer's source DMS so repeat uploads are seamless.

Validation — three layers

- **Per-column:** type, required, enum. **Normalize** messy legacy values ("sold", "SOLD", "S" → canonical `unit_status` / `deal_stage`) via a mapping table; infer date formats (MM/DD vs DD/MM).
- **Referential:** import in dependency order (units + customers *before* deals); reject a deal whose unit/customer key doesn't resolve.
- **De-duplication:** units by VIN / serial / stock_no, customers by email / phone — **surface collisions, never silently merge**.

Preview, commit, errors, re-runs

- **Errors vs warnings** split — the partial-success mechanism (warnings commit; errors hold).
- Row-level inline errors with a "show only problem rows" filter, in-app fix, undo; **downloadable annotated error file** for re-upload.
- Failed rows → staging queue, never abort the whole file.
- **Idempotent** re-runs: every row keyed on a stable `external_ref`; the bulk API accepts an `Idempotency-Key`.
- Robust parsing: BOM/encoding detection, Excel-CSV quirks, embedded commas/newlines; async background worker with an `import_id`; chunk 50–500 rows (MVP may cap row count).

F.3 Migration strategy

- Split **static/master** (units, customers — migrate days ahead) from **dynamic/transactional** (open deals/WIP — migrate at cutover).
- Advise dealers to **"drain the line"** (~2 weeks) so open WIP is minimal at go-live.
- **Migrate active data only; archive closed history as CSV** (not live records).
- **Reconciliation screen** before go-live: source-vs-target counts per entity + a sampled spot-check (e.g. 10 units, 5 customers).
- **Rollback triggers:** a hard-stop time and a **> 0.5% record-count variance auto-revert**; keep the old DMS read-accessible through cutover.
- One-time migration is the default; live two-way sync with a legacy DMS is out of scope. Offer a no-commit **dry-run**.

F.4 Import templates & bulk endpoint

Ship one downloadable template per entity, **generated from the canonical schema so they never drift**, plus a `/api/v1/bulk/{entity}` upsert endpoint (external_ref-keyed, idempotent) mirroring the wizard. Suggested columns (reconcile against Appendix A):

Entity	Template columns
units	`external_ref, vin_serial, stock_no, year, make, model, type, length, axles, capacity, mileage_hours, condition, cost, recon_cost, transport_cost, list_price, floor_price, status, lot, acquired_at, photos_ref`

customers	`external_ref, first_name, last_name, company, email, phone, address1, address2, city, state, zip, notes`
leads	`external_ref, customer_external_ref, source, status, interest_unit_ref, assigned_to, created_at, notes`
deals	`external_ref, unit_external_ref, customer_external_ref, stage, sale_price, fees, taxes, down_payment, financing_terms, salesperson, opened_at`

Schema delta. Add an `external_ref` column to every importable entity (absent today) so import is idempotent and legacy ids are preserved.

Primary sources

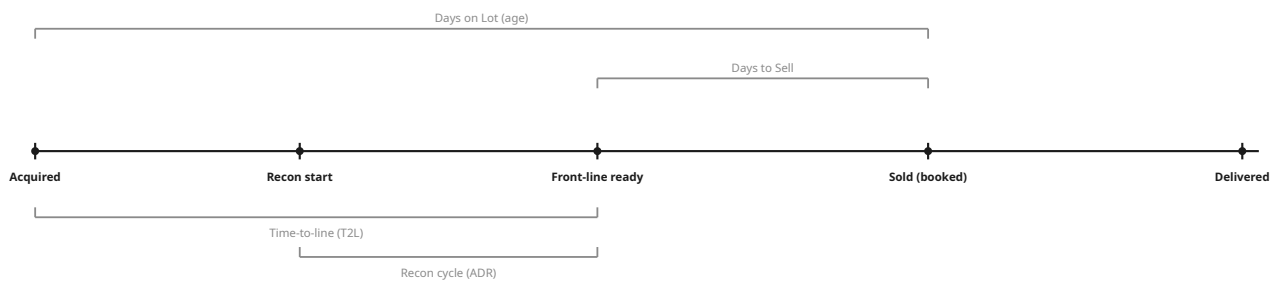
- AWS Well-Architected SaaS Lens — *Tenant Onboarding Best Practices*; multi-tenant provisioning write-ups (IaC, async billing).
- Time-to-value data — DigitalApplied *SaaS TTV Framework* (median ~1.5-day TTFV; >14-day "lost" cohort; 37.5% B2B activation).
- Import UX — OneSchema (*Building a CSV Uploader*, *Advanced Features*), Flatfile (fuzzy auto-match), Domo ETL (staging dedup), Salesforce Bulk API 2.0 (upsert-by-external-id), idempotency-key guidance.
- DMS migration — LotPulse *Switch Your DMS*, P2-Innovate *static-vs-dynamic cutover*, Concentrus *cutover plan* (reconciliation, 0.5% rollback threshold).

Appendix G · Derived-Field Formulas

Unambiguous formula definitions so two independent rebuilds compute identical numbers. The single biggest source of divergence is the **age clock**; it is resolved by persisting separate date stamps per unit and naming which clock each metric uses.

G.0 Conventions (state once, apply everywhere)

- One **day-count convention** (inclusive vs exclusive of endpoints), applied uniformly to age, days-to-sell, recon, DSO and aging buckets.
- **Every "%" field declares its denominator** (price vs cost vs market).
- One global **"sold" trigger** — booked / funded / **delivered**; default **delivered** (ASC 606). It propagates to units-sold, velocity, conversion and revenue recognition.
- Persist five date clocks per unit: `acquired_at`, `recon_started_at`, `frontline_ready_at`, `sold_at` (booked), `delivered_at`.



The five date stamps a unit must carry, and the spans derived from them. Most aging/turn ambiguity disappears once these are stored separately rather than collapsed into one "date".

G.1 Inventory & aging

Metric	Formula	Notes / variants
Days on Lot (age)	`(sold_at | today) − acquired_at`	Floor-plan/aging clock; from acquisition
Days to Sell	`sold_at − frontline_ready_at`	Retail speed; excludes recon — store **both**
Aging buckets	assign `age_days` to `[lo, hi)`	Default 0–30/31–60/61–90/90+ — **configurable**
Inventory turn (cost)	`COGS / avg_inventory_value`	Annualize × (365 / days_in_period)
Inventory turn (unit)	`units_sold / avg_units_in_stock`	Non-equivalent to cost turn — label which is shown

Total cost basis	`acquisition + recon + transport + capitalizable_fees`	"All-in"; provisional until recon RO closes
Recon cycle (ADR)	`frontline_ready_at − recon_started_at`	vs Time-to-line `frontline_ready_at − acquired_at`

G.2 Pricing & profit

Metric	Formula	Notes / variants
Front-end gross	`sale_price − total_cost_basis − pack`	Excludes F&I, holdback, incentives (configurable)
Back-end gross (F&I)	`finance_reserve + warranty + GAP + other_FI`	Each = price_to_customer - cost_to_dealer
Total gross / margin %	`(front + back); total_gross / sale_price × 100`	Margin is on **selling price**
Margin vs markup	`margin% = (p−c)/p; markup% = (p−c)/c`	Not interchangeable — declare denominator
Holding cost / day	`(amount_financed × rate)/360` or fully-loaded NADA/Cox	360 vs 365 configurable; ~$40–50/day used-unit benchmark
Age-adjusted gross	`front_end_gross − holding_per_day × age_days`	Shows margin erosion as a unit ages
Price/Cost-to-market	`price (or basis) / avg_market_like × 100`	Needs external comp feed — flag data-dependent

G.3 Sales & deal

Metric	Formula	Notes / variants
Commission	**rules engine**, not a constant	flat / %-of-gross-after-pack / mini-floor / tiered + spiffs — all configurable
Conversion (by stage)	`stage_outcomes / stage_inputs × 100`	Define lead dedup + attribution window; unwind reverts the count
Avg sale price / velocity	`Σ sale_price / units; units / days_in_period`	Exclude voided/unwound; "sold" per the global trigger
Sales tax & fees	**jurisdiction table**	Never hard-coded; base/rate/doc-fee vary by locale

G.4 Money & AR

Metric	Formula	Notes / variants

DSO	`(avg_AR / net_credit_sales) × days_in_period`	Pair with AR aging; period/denominator configurable
AR aging	bucket by `today − invoice_date`	Contracts-in-transit = its own AR sub-ledger
Balance due	`total_price − deposits − trade − rebates`	Deposit is a **liability** until delivery
Revenue recognition	at **delivery** (ASC 606, point-in-time)	"Sale date" ≠ "recognition date"; voided delivery reverses revenue + gross + commission

G.5 "Configurable" register

Every legitimately-variable choice — expose as a tenant setting, not a constant: aging-bucket boundaries · turn basis (cost vs unit) & averaging method · cost-basis inclusions · holding rate + 360/365 day-basis · all commission parameters (pack, rate, mini, tiers, commissionable base) · conversion attribution window & dedup · tax/fee jurisdiction tables · DSO period length & denominator · the global "sold" trigger.

Schema delta. `units` today has only `acquired_at` / `sold_at` and a single `cost`; add `recon_started_at`, `frontline_ready_at`, `delivered_at` and the cost components `recon_cost` / `transport_cost`. `deals` needs a front/back-gross + fees/tax/pack breakdown beyond the single `value`.

Primary sources

- Inventory/turn/aging — NADA *Analyze Your Inventory* & Slide Guide, acvmax, NetSuite, Wall Street Prep (turnover, sell-through), Lightspeed.
- Recon/T2L — Cartuul, AutoSuccess (ADR). Profit — Nimble (front/back gross), Edmunds, AccountingTools / Consero (margin vs markup), Cox Automotive / NextGear (floor-plan & holding cost), vAuto (PTM / market-days-supply).
- Commission & conversion — myCommissionCalc, Demand Local, Foureyes, evox. AR & rev-rec — Wall Street Prep / CFI / AccountingTools (DSO), Versapay, RevenueHub & Deloitte DART (ASC 606 point-in-time), Wipfli.

Appendix H · Notification & Document Catalog

Every system-generated message and legal document: its trigger, channel, recipient and template variables. **Transactional** messages (tied to a transaction the recipient is party to) are exempt from marketing opt-out; **marketing** messages intersect the GLBA Privacy Rule opt-out (Appendix E.3) and CAN-SPAM/TCPA.

Event	Channel	Recipient	Template variables	Type
Lead received	Email + in-app	Assigned salesperson, lead desk	lead_name, source, interest_unit, contact	Transactional
Quote sent	Email (+ portal)	Customer	unit, price, prep, freight, tax, total, valid_until, accept_link	Transactional
Financing decision	Email + portal	Customer, salesperson	decision, terms, next_step	Transactional
Deposit / payment received	Email	Customer, bookkeeper	amount, method (last4), invoice_no, balance_due	Transactional
Work-order status	In-app	Service mgr, inventory mgr	unit, wo_status, hours, parts	Transactional
Title cleared / lien released	Email + in-app	Office, customer	unit, title_status, state	Transactional
Delivery scheduled / en-route / delivered	SMS + email + portal	Customer, dispatch	unit, eta, carrier, tracking	Transactional
Invoice due / overdue	Email	Customer, bookkeeper	invoice_no, amount, due_at, days_overdue, pay_link	Transactional
Marketing / re-engagement	Email	Customer (opted-in)	saved_units, new_matches	**Marketing** — opt-out applies

H.1 Compliance documents

- **Privacy notice** (GLBA/Reg P) — generated, delivered, opt-out tracked (E.3).
- **E-sign consent record** — consent + document hash + signer/timestamp/IP (E.3).
- **Breach notice** — FTC report (≤30 days, ≥500 consumers) + per-state consumer notices (E.1/E.5).
- **Adverse-action / Red Flags** notices where financing is declined or identity flags fire (E.1).

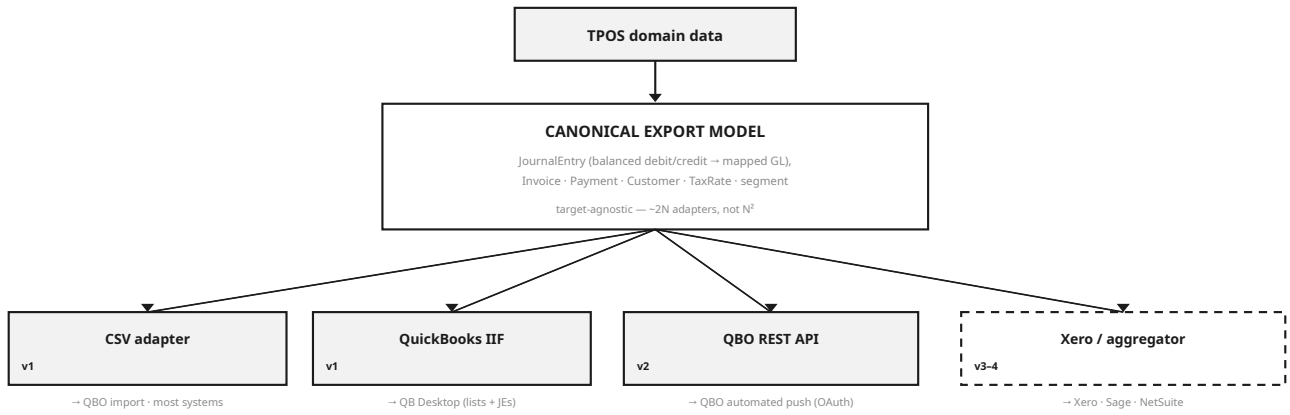
Appendix I · Accounting Export (QuickBooks & Beyond)

The bookkeeper must be able to **manually export financial transactions to QuickBooks** on demand, with other accounting systems (Xero, Sage, NetSuite) supported later **without a rewrite**. The governing reality: the dealer base is split between **QuickBooks Online (QBO)** and **QuickBooks Desktop (QBDT)** — two products with completely different ingestion paths — and no single file or API serves both well.

I.1 The options (and their hard constraints)

Option	Target	Carries / can't carry	Constraint & fit
IIF (Intuit Interchange Format)	Desktop only	Lists + transactions incl. journal entries	Intuit-deprecated ("outdated, no longer recommended"); **does not link** invoice↔payment; limited error-checking. Usable as a Desktop fallback, esp. for summary JEs.
QBO native CSV import	Online	Customers, COA, items; invoices (limited)	**Invoice CSV is blocked when sales tax is enabled** (trailer dealers always collect it) and capped at 100/upload — unreliable for detailed AR. Best for the JE-summary path.
.QBO / OFX (Web Connect)	Online/Desktop	**Bank/credit-card transactions ONLY**	Cannot carry AR/AP invoices, customers, items or GL postings. **Not viable** for this feature.
qbXML + Web Connector	Desktop	Full Desktop object model, with real linking	Correct *automated* Desktop path, but requires hosting a SOAP endpoint + a connector running on each dealer PC. Too heavy for v1; defer.
QBO Accounting API (REST/OAuth2)	Online	Invoice, Payment, SalesReceipt, Bill, JournalEntry, Deposit, Customer, Item, Account; Batch endpoint	Modern long-term engine; "click-to-push" maps to Batch. But needs OAuth2 + Intuit's **multi-week production review** (technical/security/marketing) + rate-limit backoff (≈500 req/min/realm). Phase 2.

Summary journal entries (accountant pattern)	Both	Balanced debit/credit lines to mapped GL accounts	Small, robust, decoupled; sidesteps the CSV sales-tax block and 100-invoice cap; needs no per-customer mapping. **Trade-off: no invoice-level AR aging inside QuickBooks.** Strong v1.



Target-agnostic **canonical export model** with per-target **adapters** — the no-rewrite seam. Targets become pluggable serializers (the same architecture a unified-API vendor hosts internally), turning N^2 point-to-point translators into ~2N. File adapters ship first and are *permanent* infrastructure, since QB Desktop has no clean REST API.

I.2 Architecture — canonical model + adapters

Build a thin, **export-only** internal representation once — journal entries (debit/credit lines → mapped GL accounts), plus customer / invoice / payment / tax-rate / a generic "segment" dimension — then serialize it through per-target adapters. This is the Canonical Data Model integration pattern; new targets need only a new adapter, never a rewrite of the export core. Keep the model thin so its governance cost stays below the point-to-point cost the pattern warns about for small teams.

Phase	Build	When
1 — now	Canonical model + **CSV adapter** + **QuickBooks IIF adapter**; manual on-demand **summary-JE** export	v1 — covers **both** QBO & Desktop, no Intuit review
2	**QBO REST-API adapter** (OAuth2, Batch, SyncToken) behind the same model	When dealers demand automated/scheduled push, or invoice-level detail in QBO
3	**Web Connector / qbXML** adapter for Desktop detail	If the Desktop segment's share justifies the heavier build
4	Add **Xero / Sage / NetSuite** — direct adapters, or adopt a **unified-API aggregator** (Codat / Rutter) behind the unchanged canonical model	When N > ~2 targets, or Desktop/NetSuite automation is needed

I.3 GL mapping & idempotency (required for every path)

- **Chart-of-accounts mapping wizard (one-time, per dealer).** Map TPOS buckets — trailer revenue, COGS, AR, sales-tax payable, processing fees, customer deposits — to the dealer's own QuickBooks accounts. The QBO API references accounts by `AccountRef` (the QB Account *Id*), so the wizard must resolve and store those ids; for CSV/IIF the account **names must match exactly** or rows fail/misroute. Reject postings into a **closed/locked period**.
- **Duplicate prevention.** QuickBooks has **no built-in idempotency key** on create; re-export re-posts. Use the TPOS invoice number as `DocNumber` (unique), store the returned QB `Id`, and **query-before-insert** (update, don't duplicate) on the API path. For file exports, stamp each record with its **export batch + date** so the bookkeeper is never handed the same rows twice — files have no platform-side dedupe.

I.4 Recommendation

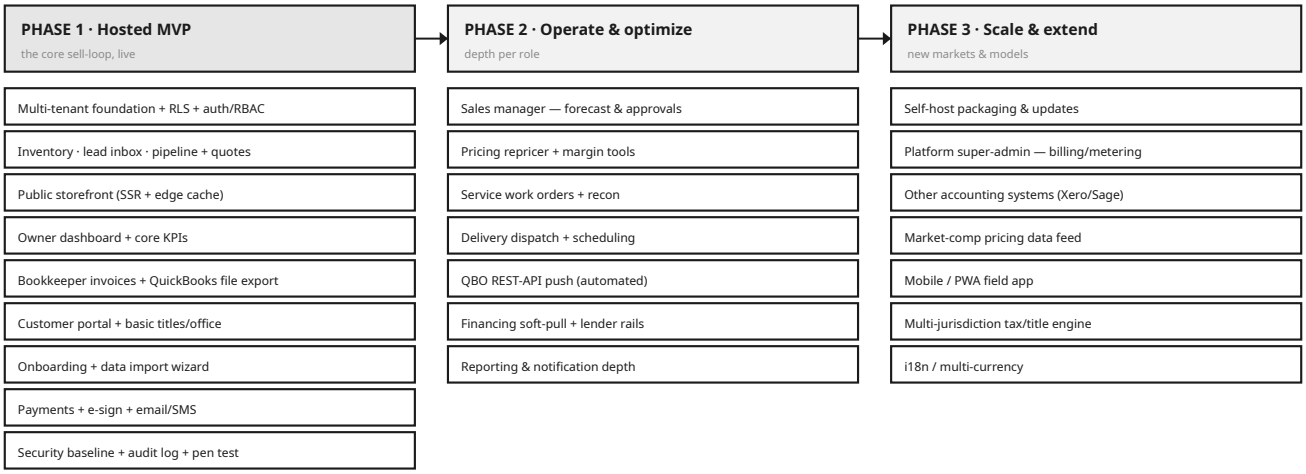
Ship v1 as a manual, on-demand *summary journal-entry* export delivered as a downloadable file (CSV for Online, IIF for Desktop), driven by the one-time GL-mapping wizard. Then QBO Accounting-API "click-to-push" batch (Phase 2), Web Connector/qbXML for Desktop detail (Phase 3), and defer a unified-API aggregator until multiple targets or automated sync justify it (Phase 4). **Why:** a downloaded file needs **no OAuth and no Intuit production review**, so it ships now; the summary JE dodges the CSV sales-tax block and invoice cap and imports cleanly into both products; and the account-mapping table + batch/dedupe stamping built for v1 are exactly what the API phase reuses. The decision knobs for what comes next: **number of targets** (1–2 → file/direct; 3+ → aggregator economical), **manual vs automated**, **cost sensitivity** (aggregators are quote-only / per-connection), and the measured **Online-vs-Desktop ratio** in the real dealer base.

I.5 Primary sources

- Intuit primary — *Export/import/edit IIF* (deprecated; no invoice↔payment link); *Import multiple invoices* (100 cap; "can't import invoices … if you have set up sales tax"); *Manually upload transactions* (.QBO = bank/credit only); *JournalEntry* (balanced debit/credit, A/R line needs an entity); *Account / AccountRef*; *Batch operations*; *Security requirements for apps*; *API call limits & throttling*; Web Connector Programmer's Guide.
- Duplicate `DocNumber` behavior — Intuit Developer community threads on duplicate-document errors & idempotency.
- Integration patterns (neutral) — Enterprise Integration Patterns, *Canonical Data Model* (the ~2N-vs-N^2 translator argument). Common accounting model — Merge.dev / Codat docs. Summary-vs-detail patterns — Ordway, CoreBridge.
- Aggregator coverage/trade-offs (**vendor marketing — treat as directional**) — Codat (incl. QB Desktop), Rutter, Merge.dev, Apideck. Tracking divergence — Xero "tracking categories" vs QBO "classes/locations."

Appendix J · MVP Scope Matrix & Release Roadmap

The specification describes the **full** product. To bid accurately, the work must be cut into releases — otherwise a bidder prices "everything at once," which is neither costable nor advisable. This appendix proposes a **Phase-1 (MVP) cutline** and tags every capability MoSCoW. PROPOSAL The cutline is the client's to confirm; it is the single largest driver of the bid.



Proposed three-phase roadmap. Phase 1 delivers the core sell-loop as a hosted product; Phase 2 adds per-role depth; Phase 3 opens new markets and delivery models. Self-host, the platform-admin billing plane, additional accounting systems and a mobile field app are deliberately deferred — each is a major cost lever that should not inflate the first bid.

J.1 Roles — Phase-1 cutline

Role (spec §6)	Phase 1	Rationale
Salesperson	**MUST**	Pipeline + quote builder is the core revenue loop
Inventory Manager	**MUST**	Units are the spine; nothing sells without inventory
Lead Generation / BDC	**MUST** (lite)	A unified lead inbox; advanced source analytics → Should
Owner / Dealer Principal	**MUST** (lite)	Core dashboard + alert feed; deep drill-downs → Should
Bookkeeper / Accounting	**MUST** (lite)	Invoices/payments + **file** accounting export (Appendix I v1)
Customer (Buyer) Portal	**SHOULD**	Quote view + deal tracker; financing/e-sign can lag
Office / Titles & Admin	**SHOULD** (basic)	Manual title tracker; full per-state DMV engine → Could
Sales Manager	**SHOULD**	Forecast/approvals add value once a team exists

Pricing Analyst	**COULD**	Repricer depends on market-comp data (Phase 3)
Service Technician	**COULD**	Work-order board; recon can be tracked manually at MVP
Delivery Dispatch	**COULD**	Delivery can be a simple status until volume warrants
Platform Super-Admin	**WON'T** (now)	Tenant provisioning can be operator-run/manual at launch

J.2 Capabilities & cross-cutting — Phase-1 cutline

Capability	Phase 1	Note
Multi-tenant foundation + RLS + auth/RBAC	**MUST**	Non-negotiable platform floor (Appendix E)
Public storefront (SSR + edge cache, lead forms)	**MUST**	The demand engine; SEO/first-paint matter
Onboarding + data import wizard (Appendix F)	**MUST**	No tenant goes live without it; the activation bottleneck
Security baseline + audit log + pen test (Appendix E)	**MUST**	Legally required once financing is offered
Notifications (transactional email/SMS)	**MUST** (core set)	Lead/quote/payment/delivery; full catalog (H) → Should
Global search	**SHOULD**	Postgres full-text at MVP; dedicated engine later
Reporting depth beyond core KPIs	**SHOULD**	Materialized core KPIs in MUST; ad-hoc/BI → Could
Financing automation + soft credit pull	**COULD**	Manual financing status at MVP; rails are heavy (App. K)
QBO REST-API accounting push	**COULD**	File export ships first (Appendix I); API needs review
Per-jurisdiction tax/title engine (multi-state)	**COULD**	Launch in 1–2 states; generalize later
Self-host single-tenant delivery	**WON'T** (now)	~Doubles release/test/support surface — defer (App. L)
Mobile / PWA field app	**WON'T** (now)	Responsive web at MVP; native field app → Phase 3
i18n / multi-currency	**WON'T** (now)	US-English / USD at launch unless required

Appendix K · Integration & Third-Party Register

Integrations are where estimates blow up: each is a vendor choice, an integration build, a credential/account dependency, and sometimes a **multi-week production-review** gate (QuickBooks and Stripe both have one). Vendor picks below are RECOMMENDED defaults, not mandates. “Owner” = who holds the contract/keys.

Service	Recommended	Phase	MVP build vs stub	Owner	Review / lead time	Notes
Payments (card + ACH)	Stripe Connect (direct charges)	1	Build	Each dealer = merchant	Connect onboarding per dealer	Keeps each dealer at PCI SAQ A; tokenize (App. E)
E-signature	Dropbox Sign / DocuSign	1–2	Build (basic)	Platform	Low	ESIGN/UETA consent flow (App. E.3); not for titles
Transactional email	Postmark / SendGrid	1	Build	Platform	Domain/DKIM setup	Per-tenant from-domain & deliverability
SMS	Twilio	1	Build	Platform	10DLC registration	Delivery/appointment alerts; A2P registration lead time
Object storage	S3 (MinIO for self-host)	1	Build	Platform	None	Photos + signed docs; off-DB (ADR #6)
Cloud / hosting	One major cloud + managed Postgres	1	Build	Platform	None	Drives infra/DevOps line (App. L/M)
QuickBooks	File export → Intuit dev app	1 → 2	Build (file)	Platform	**API: multi-week review**	File needs no review; API gated (App. I)
Soft credit pull / prequal	700Credit / bureau reseller	2	Stub at MVP	Dealer-contracted	Vendor onboarding + FCRA	Triggers GLBA/Red-Flags scope (App. E)
Financing / lender rails	RouteOne / Dealertrack	2–3	Stub at MVP	Dealer-contracted	Heavy, per-lender	Often manual at launch; big integration if automated
Freight / lane rates	Carrier API / manual	2–3	Stub / manual	Platform	Varies	Dispatch is Phase-2+ (App. J)
Market-comp pricing data	vAuto / J.D. Power feed	3	Out of MVP	Dealer-contracted	Commercial deal	Expensive licensed data; powers the repricer
Error/uptime monitoring	Sentry + metrics stack	1	Build	Platform	None	Required by NFR observability + App. E logging

Bidder takeaways. Only a handful are true MVP builds (payments, email/SMS, e-sign, storage, monitoring, QuickBooks file export). The expensive, slow-onboarding ones (credit pull, lender rails, market-comp data) are **stub-at-MVP** and dealer-contracted — confirm each is out of the Phase-1 price. Two carry **production-review lead times** that affect the schedule, not just effort: **Stripe Connect** (per-dealer onboarding) and the **QuickBooks API** (deferred to Phase 2 specifically to avoid blocking MVP).

Appendix L · Assumptions, Delivery Model & RACI

A specification is not a statement of work. These are the assumptions and ownership boundaries a bidder must fix before pricing. Defaults are (PROPOSED); each is a decision for the client.

L.1 Load-bearing assumptions (confirm each)

Open decision	Proposed default	Bid impact if changed
Release scope priced	**Phase 1 (MVP)** only (App. J)	Pricing all phases at once multiplies the bid 2–3×
Delivery model at launch	**Hosted multi-tenant only**; self-host deferred	Adding self-host ≈ +30–50% (dual release/test/support)
Visual/UX design	**Bidder produces** design system + screens from the IA wireframes	If client supplies hi-fi designs, remove the design phase
Launch jurisdiction	**US, single state/handful**, USD, English	Multi-state tax/title + i18n are sizeable adders
Mobile	**Responsive web**; no native/PWA app	A field app is a separate workstream (Phase 3)
Data migration	Self-serve import (App. F) + **assisted onboarding as a service line**	Per-format legacy DMS adapters are variable scope
Legal/compliance content	**Client provides** ToS, privacy, contract & tax/title legal text	Bidder builds the mechanism, not the legal copy (App. E)
Pen test & security audit	**In scope**, third-party, once per release	Required by the Safeguards Rule; a real line item
Environments	dev / staging / prod + IaC + CI/CD	Fewer envs cut cost but raise release risk

L.2 RACI (R = responsible, A = accountable, C = consulted, I = informed)

Workstream	Client	Vendor (bidder)	Third-party
Scope & MVP cutline sign-off	**A**	R / C	—
UX/visual design	C / A	**R**	—
Build (platform, roles, storefront)	I	**R / A**	—
Integrations (payments, email/SMS, e-sign, QB)	C	**R**	C (vendors)

Vendor accounts & credentials	**A** (commercial)	C	R (provisioning)
Security controls & audit log	I	**R / A**	—
Penetration test	A	C	**R**
Legal/compliance content	**R / A**	I	C (counsel)
Data migration per dealer	C (data)	**R**	—
Infra / DevOps / backups	I	**R / A**	C (cloud)
UAT & acceptance sign-off	**R / A**	C	—
Production app reviews (QB / Stripe)	A	**R**	C (Intuit/Stripe)

L.3 Commercial wrapper — to be completed in the SOW

Placeholders a bid must fill (intentionally not invented here): milestones & payment schedule · team composition & rate basis (fixed-bid vs T&M) · change-control process · warranty/support period & post-launch SLA · IP ownership & source escrow · acceptance criteria per milestone · liability/indemnity (ties to App. E). **Out of scope (Phase 1):** self-host packaging · platform billing/metering admin · additional accounting systems · market-comp pricing data · native mobile app · multi-state tax/title automation · i18n.

Appendix M · Estimation Worksheet (WBS)

A feature-level work breakdown for **Phase-1 (MVP)** a bidder can price against. PLANNING RANGES Figures are order-of-magnitude **person-weeks (pw)** for a small senior team on the recommended stack (ADR, App. D) — **not a quote**. Re-estimate against the confirmed cutline, the client's rates, and the assumptions in Appendix L.

Work package	Effort (pw)	Risk driver
Foundation		
Multi-tenant core — RLS, tenant context, PgBouncer/SET LOCAL, auth, RBAC	6 – 10	High — isolation correctness; CI negative test
Data model + migrations + CRUD scaffolding (Appendix A)	4 – 8	Low
DevOps — envs, IaC, CI/CD, observability, backup/DR	4 – 8	Medium
Design system + visual design from IA wireframes	6 – 12	Medium — depends on L.1 design ownership
Core domain (MVP roles)		
Inventory management (units, statuses, photos, lots)	4 – 7	Low
Lead capture + inbox + routing	3 – 5	Low
Sales pipeline + quote builder	5 – 8	Medium
Owner dashboard + KPIs (materialized read models)	3 – 6	Low
Office/titles (basic) + customer portal (basic)	4 – 7	Low
Bookkeeper invoices/payments + QuickBooks file export (App. I v1)	4 – 7	Medium — GL mapping + idempotency
Public storefront (SSR + edge cache, detail, lead forms)	4 – 7	Medium — SEO + responsive
Cross-cutting		
Permissions enforcement + field-level masking	2 – 4	Medium — pervasive
Notifications (core transactional set, App. H)	3 – 5	Low
Onboarding + data import wizard (App. F)	5 – 9	High — messy real-world data
Global search (Postgres FTS)	2 – 4	Low
Integrations (MVP subset, App. K)		

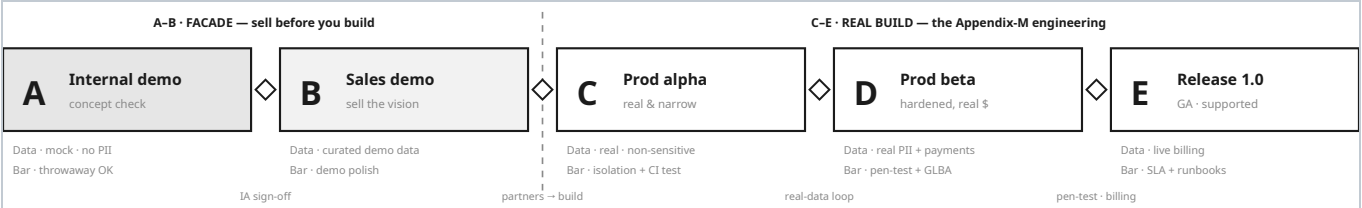
Payments — Stripe Connect (tokenized, per-dealer)	3 – 6	Medium — Connect onboarding
E-signature + email + SMS	3 – 6	Medium — A2P/DKIM setup
Security & quality		
Security controls + audit log (App. E hard gates)	4 – 7	High — compliance baseline
Third-party penetration test + remediation	2 – 4	Medium — external cost + fixes
Test automation (unit/integration/e2e + tenant-isolation)	5 – 9	Medium
UAT + hardening + bug-fix	4 – 8	Medium
Overhead		
PM / coordination / ceremonies (≈ 15–20% applied to the above)	+ overhead	—

Phase-1 rollup (engineering, excl. PM overhead): ≈ 80 – 150 person-weeks. With PM overhead, ≈ **95 – 175 pw** → roughly **6 – 12 calendar months** with a delivery team of ~3–4 FTE, plus a designer and part-time PM. **Cost** is deliberately omitted — multiply by the client's confirmed blended rate. The range is wide on purpose: it tightens dramatically once the four levers in Appendix L (scope cutline, delivery model, design ownership, launch jurisdiction) are fixed.

Estimation basis & caveats. Ranges assume the recommended stack (Postgres + RLS, modular monolith, batteries-included framework — App. D); a senior team familiar with multi-tenant SaaS; integrations limited to the MVP subset (App. K) with the rest stubbed; and the Appendix L assumptions holding. They exclude: self-host, the deferred integrations, market-comp data, native mobile, multi-state tax/title, i18n, and ongoing run-cost. These are **planning figures to scope a bid**, not a fixed-price commitment.

Appendix N · Delivery Stages (Internal Demo → GA)

A **maturity** ladder, orthogonal to the feature-depth roadmap (Appendix J): each stage takes a slice of the Phase-1 scope and raises the bar on **what is real** — data, persistence, security, money, SLA. The decisive boundary is between **B and C**. Stages A–B are facade/prototype-grade (and A is **largely already built**); C–E are the real engineering priced in Appendix M. The governing rule: **data sensitivity gates the quality bar, not the calendar.**



Five stage-gates from internal demo to general availability. The dashed line marks the facade→real-build boundary: A–B are a few person-weeks of polish on the existing prototype; C–E are essentially the entire Appendix-M estimate. Tenant isolation becomes mandatory at C (real data); the legally-required pen test and GLBA Safeguards baseline land at D (real PII + money); SLA, billing and support gate E.

Stage	Audience & goal	Scope at this stage	What's real	Quality / security bar	Exit gate
A · Internal demo	Internal stakeholders — validate IA & the one-record-many-lenses idea; lock the cutline	Clickable prototype: storefront + 12 role dashboards on mock data	Nothing behind it — mock data, no auth/PII	Renders clean; throwaway code OK	IA & Appendix-J cutline signed off · **(already built)**
B · Sales demo	Prospects, design partners, investors — sell the vision, win LOIs	Same prototype, polished: branding, stable URL, demo script, reset-to-clean data, one believable tenant	Still a facade — curated demo data, no money/PII	Demo-grade: never breaks live, phone-presentable	Partners committed · pricing validated · **go/no-go to build**
C · Production alpha	Internal + 1–2 design-partner dealers, controlled — prove the real architecture on the smallest valuable slice	Real multi-tenant core (RLS/auth/RBAC) + core MUST roles: inventory, lead, pipeline+quote, owner dashboard, storefront, import v1	**Real persistence**; real but non-sensitive data; no financing PII or money yet	Happy paths work; **tenant isolation + CI negative test green**; hardening in progress; no pen test	Sell-loop works on real data for a partner; isolation proven
D · Production beta	Beta dealer cohort with real buyers — validate under real load & money;	All MUST + most SHOULD: real payments (Stripe Connect), e-sign, QB file export,	**Real PII + real payments** — now	Hardened; **pen test done + remediated**; audit log,	Stable across cohort; pen-test issues

	complete compliance baseline	notifications, self-serve onboarding, customer portal	compliance-bearing	observability, backups; GLBA Safeguards baseline; SLA targeted not guaranteed	closed; billing ready
E · Release 1.0 (GA)	Open self-serve signup, paying dealers — commercial launch of Phase 1	Full Appendix-J Phase-1 cutline, polished; self-serve onboarding + live billing	Everything real + monetized	GA: UAT signed off, runbooks, backup/DR drills, on-call, change-control; **99.9% SLA honored**; warranty/support begins	GA criteria met → 1.0 ships; Phase-2 backlog begins

N.1 Effort & the two principles

- **A/B are facade; C/D/E are the build.** A is essentially done; B is ~1–3 pw of polish on the existing prototype. C–E together are the full **≈95–175 pw** Appendix-M estimate, split roughly: **C** ≈ foundation + core MUST roles (~40–60% of MVP), **D** ≈ the remainder + security/QA/pen-test packages, **E** ≈ the UAT/hardening/launch-readiness tail + billing/support setup. Do not let the polished sales demo imply the system is “almost done.”
- **Data sensitivity gates the bar, not time.** Tenant isolation is required the moment real data exists (**C**). Real PII and money — and therefore the legally-required pen test and GLBA Safeguards baseline (Appendix E) — only enter at **beta (D)**, the stage not to rush. SLA, runbooks, billing and support gate **GA (E)**.

Cross-references: stage scope maps to the MoSCoW tags and roadmap in **Appendix J**; integration availability per stage to **Appendix K** (e.g., QuickBooks *file* export at D, QBO API in Phase 2/post-GA; soft-credit-pull stubbed until financing); security gates to **Appendix E**; effort to **Appendix M**.